

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC FPT**

**KIẾN TRÚC NHẬN THỨC HAI TẦNG CHO PHÁT HIỆN
VÀ PHẢN HỒI MỐI ĐE DỌA TỰ ĐỘNG SỬ DỤNG AI
TÁC TỬ**

thực hiện bởi

Nguyễn Đức Bình

MSHV: 24MSE13183 – Lớp: MSE23HN

Luận văn được nộp để đáp ứng yêu cầu
của học vị Thạc sĩ Kỹ thuật Phần mềm

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC FPT**

**KIẾN TRÚC NHẬN THỨC HAI TẦNG CHO PHÁT HIỆN
VÀ PHẢN HỒI MỐI ĐE DỌA TỰ ĐỘNG SỬ DỤNG AI
TÁC TỬ**

thực hiện bởi

Nguyễn Đức Bình

MSHV: 24MSE13183 – Lớp: MSE23HN

Luận văn được nộp để đáp ứng yêu cầu
của học vị Thạc sĩ Kỹ thuật Phần mềm

Giảng viên hướng dẫn:

TS. Bùi Văn Hiệu

TS. Đặng Văn Hiếu

Tóm tắt

Trong kỷ nguyên chuyển đổi số và bùng nổ lưu lượng mạng, các Trung tâm Điều hành An ninh (SOC) hiện đại đang đối mặt với tình trạng quá tải cảnh báo (Alert Fatigue) nghiêm trọng, khi khối lượng nhật ký thu thập từ các hệ thống giám sát vượt xa năng lực phân tích thủ công của nhân sự trực ca. Các giải pháp phòng thủ truyền thống bộc lộ rõ hạn chế: bộ lọc chữ ký tĩnh phát sinh tỷ lệ báo động giả rất cao do thiếu khả năng phân tích ngữ cảnh, trong khi các kịch bản SOAR lập trình sẵn chỉ đáp ứng được các tình huống định trước. Việc dịch chuyển sang ứng dụng Mô hình Ngôn ngữ Lớn (LLM) mở ra tiềm năng tự động hóa suy luận an ninh theo ngữ cảnh tự nhiên; tuy nhiên, hướng tiếp cận này hiện chưa thể triển khai rộng rãi do rào cản về độ trễ xử lý, chi phí tính toán lớn, các nguy cơ đối kháng nói chung (điển hình như tiêm nhiễm câu lệnh qua nhật ký - Log Prompt Injection) và rủi ro ảo giác AI. Để giải quyết các thách thức trên, luận văn đề xuất SENTINEL, một kiến trúc an ninh nhận thức hai tầng vận hành hoàn toàn cục bộ (air-gapped), thiết kế theo nguyên lý đặt phán quyết rẽ đứng trước phán quyết đất. Tầng 1 kết hợp bộ lọc thống kê Welford $\mathcal{O}(1)$ và Cổng Học máy LightGBM nhằm xử lý nhiễu nền ở tốc độ đường truyền, xả tải từ 97,5% lưu lượng mà không tiêu tốn tài nguyên LLM, giúp giảm độ trễ trung vị toàn tuyến từ 17.174,7 ms xuống còn 0,88 ms. Tầng 2 vận hành cỗ máy tác tử LangGraph kết hợp cơ chế truy xuất lai Dual-RAG (FAISS + BM25 RRF $k = 60$) trên 433 mục tri thức MITRE ATT&CK, trong khi kênh hoãn Awaiting HITL giúp giảm 84,24% tải công việc cho chuyên viên mà vẫn đảm bảo phủ 95,0% mối đe dọa thật. Cuối cùng, cơ chế Đóng gói Nonce phân định bảo chứng cấu trúc đạt khả năng kháng triệt để trước 678 mẫu tấn công đối kháng (bao gồm tiêm nhiễm câu lệnh qua nhật ký), và chuỗi HMAC-SHA256 bảo đảm khả năng phát hiện hiệu quả các hành vi giả mạo vết kiểm toán pháp y.

Lời cảm ơn

Để hoàn thành công trình nghiên cứu này và đạt được học vị Thạc sĩ Kỹ thuật Phần mềm, tôi đã nhận được sự hỗ trợ, động viên và đùm bọc quý báu từ quý Thầy Cô, đồng nghiệp cùng gia đình.

Trước hết, tôi xin bày tỏ lòng biết ơn chân thành và sự kính trọng sâu sắc nhất tới hai thầy hướng dẫn khoa học, TS. Bùi Văn Hiệu và TS. Đặng Văn Hiếu. Với tri thức học thuật uyên bác, sự định hướng chiến lược chuẩn xác và tinh thần làm việc nghiêm túc, quý Thầy đã luôn dành thời gian kiên nhẫn chỉ bảo, định hướng tư duy phản biện và truyền cảm hứng nghiên cứu cho tôi trong suốt chặng đường thực hiện luận văn. Những góp ý chuyên môn sắc bén của quý Thầy không chỉ giúp tôi hoàn thiện công trình này mà còn là hành trang tri thức vô giá cho sự nghiệp nghiên cứu an toàn thông tin và trí tuệ nhân tạo của tôi trong tương lai.

Tôi xin trân trọng gửi lời tri ân tới Ban Giám hiệu, Ban Lãnh đạo Viện Quản trị & Công nghệ FSB cùng toàn thể quý Thầy Cô Trường Đại học FPT đã truyền dạy nền tảng tri thức lý thuyết và thực tiễn vững chắc trong một môi trường nghiên cứu chuyên nghiệp. Tôi cũng xin chân thành cảm ơn Ban Lãnh đạo cùng toàn thể đồng nghiệp tại Cục C12, Trung tâm Dữ liệu Quốc gia. Sự tin tưởng, điều kiện thuận lợi về thời gian cùng những kinh nghiệm thực chiến phong phú từ đơn vị đã đem lại góc nhìn thực tiễn sâu sắc, góp phần quan trọng vào quá trình thiết kế, thực nghiệm và hoàn thiện hệ thống SENTINEL.

Cuối cùng, tôi xin dành trọn lòng tri ân sâu sắc nhất tới gia đình thân yêu, đặc biệt là người vợ hiền cùng con nhỏ. Sự hy sinh thầm lặng, lòng kiên nhẫn và nguồn động viên không ngừng nghỉ của gia đình trong suốt quá trình tôi miệt mài thực hiện nghiên cứu chính là điểm tựa vững chắc nhất giúp tôi hoàn thành luận văn này. Mặc dù đã nỗ lực hết mình, luận văn khó tránh khỏi những thiếu sót nhất định; tôi rất mong nhận được sự chỉ dẫn và đóng góp quý báu từ quý Thầy Cô trong Hội đồng cùng quý độc giả.

Mục lục

Tóm tắt	i
Lời cảm ơn	ii
Danh sách hình vẽ	iv
Danh sách bảng	v
Danh mục các từ viết tắt	vi
1 Giới thiệu	1
1.1 Bối cảnh và Động lực Nghiên cứu	1
1.2 Mục tiêu, Câu hỏi Nghiên cứu, Phạm vi và Đóng góp	2
1.3 Cấu trúc của Luận văn	3
2 Cơ sở Lý thuyết và Tổng quan Nghiên cứu	4
2.1 Thực trạng Vận hành SOC và Nút thắt Nhận thức	4
2.2 Lý thuyết Luật tắt định, Thông kê Trực tuyến và Học máy Tầng 1	5
2.3 Mô hình Ngôn ngữ Lớn Cục bộ và Trí tuệ Tác tử Tầng 2	5
2.4 An ninh Đối kháng AI và Mật mã học Kiểm toán Nhật ký	6
2.5 Tổng quan Nghiên cứu Liên quan và Khoảng trống Nghiên cứu	7
3 Thiết kế Hệ thống và Triển khai Kỹ thuật	9
3.1 Phương pháp Nghiên cứu	9
3.2 Kiến trúc Tổng thể SENTINEL và Tích hợp Ngăn xếp SOC	10
3.3 Tầng 1: Bộ lọc Tốc độ Đường truyền và Cổng Học máy	11
3.4 Tầng 2: Tác tử Nhận thức LangGraph và Bộ nhớ Đe dọa	13
3.5 Cơ chế Truy xuất Tri thức Lai Dual-RAG	14
3.6 An ninh Đối kháng AI và Niêm phong Kiểm toán Mật mã	15
4 Thực nghiệm và Đánh giá	17
4.1 Hiệu năng Xả tải Lưu lượng và Kinh tế học Tầng lọc	17
4.2 Rào chắn An ninh Đối kháng AI và Toàn vẹn Kiểm toán Mật mã	20
4.3 Suy luận Nhận thức Tác tử và Quy kết Kỹ thuật Tấn công	22
4.4 Phân tích Khả năng Mở rộng Hạ tầng (Scalability Analysis)	27
5 Kết luận	30
Tài liệu tham khảo	1

Danh sách hình vẽ

Hình 1.	Sơ đồ kiến trúc tổng thể SENTINEL.	11
Hình 2.	Sơ đồ chi tiết Tầng 1.	12
Hình 3.	Đồ thị trạng thái tác tử Tầng 2.	14
Hình 4.	Sơ đồ truy xuất Dual-RAG và rào chắn neo bằng chứng.	15
Hình 5.	Cơ chế đóng gói Nonce và chuỗi niêm phong HMAC.	16
Hình 6.	Phân phối tích lũy độ trễ ECDF trên 500 sự kiện	19
Hình 7.	Tỷ lệ chặn của lớp lọc tĩnh và tỷ lệ báo nhầm	22
Hình 8.	Độ chính xác quy kết kỹ thuật đối chiếu trần RAG	24
Hình 9.	Phân loại cảnh báo tại Tầng 2 theo phễu nhận thức	25
Hình 10.	Đánh giá bóc tách thành phần và bốn trục RAGAS	27

Danh sách bảng

Bảng 1.	So sánh đối chiếu với các giải pháp hiện hành	8
Bảng 2.	Hiệu quả xả tải và độ trễ theo từng tầng xử lý	18
Bảng 3.	So sánh thông lượng giữa SENTINEL và các cấu hình đối chứng . .	19
Bảng 4.	Kết quả đánh giá các lớp rào chắn an ninh đối kháng	20
Bảng 5.	Đánh giá độ chính xác quy kết kỹ thuật MITRE ATT&CK	23

Danh mục các từ viết tắt

Từ viết tắt	Định nghĩa đầy đủ
CTI	Cyber Threat Intelligence (Tình báo mối đe dọa mạng)
ECDF	Empirical Cumulative Distribution Function (Hàm phân phối tích lũy thực nghiệm)
FAISS	Facebook AI Similarity Search (Thư viện truy xuất tương đồng vector)
GGUF	GPT-Generated Unified Format (Định dạng lưu trữ mô hình hợp nhất)
HITL	Human-in-the-Loop (Chế độ tương tác con người trong vòng lặp)
HMAC	Hash-based Message Authentication Code (Mã xác thực thông điệp dựa trên hàm băm)
IDS / IPS	Intrusion Detection / Prevention System (Hệ thống phát hiện và ngăn ngừa xâm nhập)
LLM	Large Language Model (Mô hình ngôn ngữ lớn)
MITRE ATT&CK	MITRE Adversarial Tactics, Techniques, and Common Knowledge (Khung tri thức chiến thuật và kỹ thuật tấn công)
RAG	Retrieval-Augmented Generation (Kiến trúc sinh văn bản tăng cường truy xuất)
RAGAS	Retrieval-Augmented Generation Assessment (Khung đánh giá chất lượng truy xuất và suy luận RAG)
RRF	Reciprocal Rank Fusion (Thuật toán hợp nhất xếp hạng nghịch đảo)
SIEM	Security Information and Event Management (Quản lý thông tin và sự kiện an ninh)
SOAR	Security Orchestration, Automation, and Response (Điều phối, tự động hóa và phản hồi an ninh)
SOC	Security Operations Center (Trung tâm điều hành an ninh mạng)
WAF	Web Application Firewall (Tường lửa ứng dụng Web)

Chương 1

Giới thiệu

Chương này xác lập bối cảnh nghiên cứu và bài toán trung tâm của SENTINEL, một kiến trúc an ninh nhận thức hai tầng tự động hóa quy trình phát hiện và phản hồi sự cố trong các Trung tâm Điều hành An ninh (SOC), cùng mục tiêu, câu hỏi nghiên cứu, đối tượng, phạm vi và đóng góp khoa học của luận văn.

1.1 Bối cảnh và Động lực Nghiên cứu

Trong kỷ nguyên chuyển đổi số và bùng nổ lưu lượng mạng, các Trung tâm Điều hành An ninh (SOC) hiện đại đang đối mặt với tình trạng quá tải cảnh báo (Alert Fatigue) nghiêm trọng, khi khối lượng nhật ký thu thập mỗi ngày lên tới hàng triệu sự kiện vượt xa năng lực phân tích thủ công [1]. Nhằm tránh bỏ lọt sự cố, các hệ thống giám sát được cấu hình nghiêng về phía tăng độ nhạy, dẫn đến việc phần lớn cảnh báo gửi về hàng đợi chỉ ghi nhận hoạt động vận hành bình thường và không thực sự yêu cầu sự can thiệp trực tiếp của chuyên viên [2, 3]. Do đó, nút thắt cổ chai của SOC hiện đại không nằm ở năng lực thu thập dữ liệu, mà nằm ở khả năng phân bổ nguồn lực chú ý khan hiếm của nhân sự trực ca.

Ba lớp phòng thủ truyền thống gồm tường lửa kết hợp hệ thống phát hiện xâm nhập (IDS/IPS) dựa trên chữ ký tĩnh, nền tảng SIEM gom tương quan dữ liệu bằng luật viết tay, và kịch bản SOAR lập trình sẵn bộc lộ rõ hạn chế: thiếu khả năng suy luận ngữ cảnh động và chỉ ứng phó được các tình huống định trước [4]. Những sự kiện vượt qua ba lớp phòng thủ này đều đẩy về hàng đợi thủ công, buộc chuyên viên phải thực hiện chuỗi thao tác tốn thời gian: trích xuất nhật ký thô, tái dựng hành vi địa chỉ nguồn, đối chiếu tài sản nội bộ và quy kết kỹ thuật tấn công trước khi ra quyết định xử lý. Quy trình tuần tự này vừa

tạo ra rào cản thời gian gây tổn động hàng đợi, vừa chịu rào cản ngữ cảnh do bằng chứng quyết định nằm rải rác trên nhiều bản ghi phi cấu trúc.

Dịch chuyển sang ứng dụng Mô hình Ngôn ngữ Lớn (LLM) mở ra tiềm năng tự động hóa suy luận an ninh theo ngữ cảnh tự nhiên; tuy nhiên, hướng tiếp cận này đối mặt với ba rào cản lớn: (1) độ trễ suy luận hàng giây của LLM mâu thuẫn với tốc độ dữ liệu đường truyền [5]; (2) tầng suy luận AI trở thành mục tiêu tấn công đối kháng qua kỹ thuật tiêm nhiễm câu lệnh (Log Prompt Injection) [6], đòi hỏi vết kiểm toán phải được niêm phong bảo đảm tính toàn vẹn; và (3) dữ liệu an ninh nội bộ bắt buộc vận hành cục bộ (air-gapped) trên phần cứng hữu hạn do yêu cầu bảo mật nghiêm ngặt [7]. Khoảng cách 4 đến 5 bậc độ lớn về chi phí tính toán giữa luật thống kê truyền thống ($\ll 1$ ms) và LLM (hàng giây) đặt ra yêu cầu phải thiết kế kiến trúc SENTINEL theo nguyên lý *đặt phán quyết rẽ đứng trước phán quyết đất*: xả tải nhiều nền ở tầng lọc tốc độ cao và chỉ gọi tầng suy luận LLM cho các sự kiện thực sự cần thiết.

1.2 Mục tiêu, Câu hỏi Nghiên cứu, Phạm vi và Đóng góp

Để giải quyết bài toán trung tâm, mục tiêu tổng quát của luận văn được chia tách thành ba trục nghiên cứu độc lập nhưng hỗ trợ chặt chẽ lẫn nhau, đặt tương ứng với ba câu hỏi nghiên cứu (RQ) và các đóng góp khoa học chính. Toàn bộ thiết kế và kết quả thực nghiệm định lượng được minh chứng tại Chương 4.

Trục thứ nhất tập trung vào phân tầng lưu lượng: thiết kế đường ống lọc hai chặng phi trạng thái ở tốc độ đường truyền nhằm xả tải dữ liệu tại tầng tính toán rẻ. RQ1 được xác lập như sau: *Làm thế nào để thiết kế một kiến trúc phân tầng có khả năng xả tải tự động luồng dữ liệu an ninh ở tốc độ đường truyền nhằm giải quyết nút thắt cổ chai về độ trễ và tài nguyên của Mô hình Ngôn ngữ Lớn?* Đóng góp tương ứng là định lượng nguyên lý đặt phán quyết rẽ đứng trước phán quyết đất và công bố tỷ lệ xả tải kèm tỷ lệ tấn công nền mà nó được đo trên đó.

Trục thứ hai tập trung vào an toàn suy luận và kiểm toán: bảo vệ mô hình ngôn ngữ bằng

rào chắn cấu trúc và niêm phong vết pháp y. RQ2 được xác lập như sau: *Phương pháp luận và cơ chế bảo mật nào chống lại rủi ro đối kháng qua nhật ký nhằm bảo vệ luồng suy luận AI, đồng thời bảo đảm tính toàn vẹn của chứng cứ pháp y?* Đóng góp tương ứng là cơ chế Đóng gói Dữ liệu Phân định với Nonce mật mã (Delimited Data Encapsulation), bảo chứng cấu trúc bất định độc lập với bộ phân loại xác suất [8].

Trục thứ ba tập trung vào suy luận nhận thức và phân loại sự cố: xây dựng tác tử suy luận tích hợp tri thức an ninh chuyên ngành. RQ3 được xác lập như sau: *Làm thế nào để tích hợp năng lực suy luận có trạng thái và tra cứu tri thức chuyên ngành vào Tác tử AI nhằm tự động hóa phân tích, quy kết kỹ thuật tấn công và sinh báo cáo minh bạch?* Đóng góp tương ứng là tác tử LangGraph có trạng thái vận hành trên kho tri thức MITRE ATT&CK chuẩn STIX, kết hợp rào chắn neo-RAG hạn chế ảo giác mô hình.

Phạm vi và phương pháp luận của luận văn được xác lập cụ thể: Khách thể nghiên cứu là quy trình tự động hóa phân tích, xả tải cảnh báo và bảo vệ mô hình AI trong SOC. Đối tượng nghiên cứu bao gồm thuật toán phân tầng tốc độ cao (bộ luật chữ ký tầng ứng dụng Rule-based, thống kê Welford $\mathcal{O}(1)$ kết hợp Cổng Học máy LightGBM), cơ chế phòng thủ đối kháng bất định (Delimited Data Encapsulation và HMAC-SHA256), cùng tác tử suy luận an ninh có trạng thái (LangGraph FSM) tích hợp truy xuất tri thức lai (Dual-RAG FAISS + BM25 RRF). Về phạm vi thực nghiệm, SENTINEL được đánh giá trên ba tập benchmark CSE-CIC-IDS2018 [9], CSIC 2010 [10] và DAPT 2020 [11], kết hợp 823 mẫu đối kháng (AdvBench [12], deepset [13], jackhhao [14]) trên máy trạm cách ly mạng (air-gapped).

1.3 Cấu trúc của Luận văn

Chương 2 hệ thống hóa cơ sở lý thuyết và tổng quan các công trình liên quan nhằm xác định khoảng trống nghiên cứu. Chương 3 trình bày phương pháp luận nghiên cứu và thiết kế kỹ thuật chi tiết của hệ thống SENTINEL. Chương 4 trình bày kết quả đánh giá thực nghiệm định lượng trong ba mục, mỗi mục ứng với một câu hỏi nghiên cứu, theo đúng thứ tự đã nêu ở trên. Chương 5 tổng kết các đóng góp, thảo luận về những hạn chế và đề xuất hướng phát triển trong tương lai.

Chương 2

Cơ sở Lý thuyết và Tổng quan Nghiên cứu

Chương này trình bày các nguyên lý lý thuyết nền tảng của luận văn, bao gồm: thực trạng vận hành SOC và nút thắt nhận thức, cơ sở luật tất định, thống kê trực tuyến và học máy Tầng 1, kiến trúc tác tử và mô hình ngôn ngữ lớn Tầng 2, nguy cơ đối kháng và kiểm toán mật mã, cùng tổng quan các nghiên cứu liên quan nhằm xác định khoảng trống nghiên cứu mà SENTINEL giải quyết.

2.1 Thực trạng Vận hành SOC và Nút thắt Nhận thức

Mục này đi sâu phân tích các nguyên nhân kiến trúc cốt lõi gây nên tình trạng quá tải cảnh báo đã được phác thảo tại Chương 1. Trong mô hình SOC tiêu chuẩn, công tác giám sát dựa vào việc hợp nhất nhật ký thô từ các cảm biến như Tường lửa thế hệ mới (NGFW), Hệ thống phát hiện xâm nhập (IDS/IPS) và giải pháp Phản hồi Điểm cuối (EDR) về nền tảng SIEM tập trung [1], với khối lượng vượt xa năng lực phân tích thủ công của con người [15]. Nút thắt khởi nguồn từ cơ chế vận hành của các cảm biến đầu vào: chúng thực hiện phán quyết chủ yếu dựa trên chữ ký tĩnh hoặc các luật tương quan tất định. Do áp lực tránh bỏ lọt sự cố luôn đi kèm thiệt hại lớn, người vận hành bị buộc phải hạ ngưỡng phát hiện. Tuy nhiên, việc hạ ngưỡng trong các hệ thống dựa trên chữ ký chỉ làm gia tăng khối lượng báo động giả gửi về hàng đợi mà không thể nâng cao năng lực phân tích ngữ cảnh [2, 3].

Ở lớp trên, các nền tảng Điều phối và Tự động hóa An ninh (SOAR) được triển khai nhằm xả tải thao tác bằng cách thực thi các kịch bản ứng phó (playbooks) lập trình sẵn [4]. Dù vậy, ranh giới của SOAR bị siết chặt bởi tính cố định của kịch bản: một playbook chỉ kích hoạt thành công khi cảnh báo khớp chính xác với tình huống đã được lường trước. Đối với

các chuỗi tấn công phức tạp, hành vi bất thường mới hoặc bằng chứng phi cấu trúc nằm rải rác, cả ba lớp SIEM, IDS/IPS và SOAR đều không thể hình thành phán quyết ngữ cảnh. Toàn bộ các ca nghi ngờ này buộc phải chuyển về hàng đợi thủ công, biến chuyên viên trực ca thành nút thắt cổ chai nhận thức duy nhất của toàn bộ hệ thống.

2.2 Lý thuyết Luật tắt định, Thống kê Trực tuyến và Học máy Tầng 1

Yêu cầu vận hành ở tốc độ đường truyền đặt ra ràng buộc chặt chẽ về mặt thuật toán cho Tầng 1: các cơ chế xử lý phải đạt độ phức tạp thời gian và bộ nhớ hằng số $\mathcal{O}(1)$. Đầu tiên, lớp phòng thủ dựa trên luật (Rule-based) sử dụng các tập hợp đối sánh tĩnh và tra cứu cổng dịch vụ để loại bỏ tức thời các hành vi bất thường thô mà không tiêu tốn tài nguyên tính toán. Tiếp theo, cơ chế theo dõi đường nền áp dụng công thức truy hồi tăng dần Welford [16] để cập nhật liên tục giá trị trung bình μ_k và tổng bình phương độ lệch S_k theo từng quan sát, tính toán độ lệch chuẩn $\sigma_k = \sqrt{S_k/(k-1)}$ và điểm Z-score động mà không cần lưu trữ nhật ký quá khứ:

$$\mu_k = \mu_{k-1} + \frac{x_k - \mu_{k-1}}{k}, \quad S_k = S_{k-1} + (x_k - \mu_{k-1})(x_k - \mu_k) \quad (2.1)$$

Cuối cùng, các mô hình Học máy dựa trên Cây quyết định tăng cường độ dốc (GBDT), tiêu biểu là thuật toán LightGBM [17], cung cấp năng lực phân loại nhanh các mẫu dữ liệu đa chiều. Việc kết hợp lọc luật tắt định, chuẩn hóa thống kê Z-score và phân loại học máy tạo thành tuyến phòng thủ đa tầng tốc độ cao, vừa đảm bảo xả tải lưu lượng lớn vừa duy trì tính ổn định trước các biến thể dữ liệu đối kháng.

2.3 Mô hình Ngôn ngữ Lớn Cục bộ và Trí tuệ Tác tử Tầng 2

Vận hành mô hình suy luận hoàn toàn cục bộ là điều kiện bắt buộc để bảo đảm chủ quyền dữ liệu an ninh nội bộ, nhưng đồng thời đặt ra giới hạn nghiêm ngặt về tài nguyên bộ nhớ GPU. Kỹ thuật lượng tử hóa giúp nén biểu diễn trọng số sang lưới số nguyên thô hơn, đánh

đổi một lượng nhỏ độ trung thực số học để giảm đáng kể dung lượng bộ nhớ [18]. Ở định dạng GGUF Q4_K_M, mô hình chuyên biệt an ninh Foundation-Sec-8B-Instruct [19, 20] chỉ chiếm khoảng 7–8 GB VRAM, thừa đủ không gian cho bộ đệm ngữ cảnh và chỉ mục truy xuất trên card đồ họa GPU cục bộ.

Tầng suy luận điều phối quy trình phân tích thông qua đồ thị trạng thái LangGraph [21]. Nhằm khắc phục hạn chế ảo giác và neo phán quyết vào chứng cứ thực tế [22], hệ thống kết hợp kỹ thuật truy xuất thông tin lai giữa tìm kiếm véc-tơ dày (FAISS) [23] và đối sánh từ khóa thưa (BM25) [24]. Kết quả truy xuất từ hai phương pháp được hợp nhất theo thứ hạng bằng thuật toán Reciprocal Rank Fusion (RRF) [25]:

$$RRF_Score(d) = \sum_{m \in M} \frac{1}{k + r_m(d)} \quad (2.2)$$

giúp đối chiếu minh bạch dữ liệu nhật ký với các mã kỹ thuật MITRE ATT&CK [26] và hướng dẫn ứng phó sự cố NIST SP 800-61r2 [27].

2.4 An ninh Đối kháng AI và Mật mã học Kiểm toán Nhật ký

Tích hợp Mô hình Ngôn ngữ Lớn vào quy trình phân tích an ninh làm phát sinh rủi ro bị tấn công tiêm nhiễm câu lệnh qua nhật ký (Log Prompt Injection) [6, 8]. Do nội dung nhật ký do chính bên tấn công khởi tạo, các giải pháp phòng thủ dựa trên phân loại nội dung hoặc lọc từ khóa xác suất thường dễ bị qua mặt trước các biến thể câu lệnh đối kháng mới [28]. Căn cứ lý thuyết đó đặt ra yêu cầu phải bảo vệ tầng suy luận bằng cơ chế cách ly cấu trúc tắt định (Delimited Data Encapsulation), phân tách ranh giới tuyệt đối giữa chỉ thị điều khiển và dữ liệu thô bị nghi nhiễm.

Đối với tính toàn vẹn của hồ sơ phân tích, các vết chứng cứ pháp y được niêm phong theo chuỗi bằng thuật toán mã hóa HMAC-SHA256 [29] sử dụng khóa bí mật cục bộ. Về mặt ranh giới lý thuyết, cơ chế mã hóa đối xứng HMAC đảm bảo khả năng phát hiện mọi hành vi chỉnh sửa hoặc giả mạo nhật ký, nhưng không thay thế cho thuộc tính chống chối bỏ (non-repudiation) vốn đòi hỏi hạ tầng chữ ký số bất đối xứng.

2.5 Tổng quan Nghiên cứu Liên quan và Khoảng trống Nghiên cứu

Nghiên cứu ứng dụng trí tuệ nhân tạo trong vận hành an ninh mạng đã tiến triển qua ba nhóm giải pháp kiến trúc chính, theo khảo sát hệ thống của Zhang và cộng sự [30].

Nhóm thứ nhất, phòng thủ doanh nghiệp truyền thống, gồm các nền tảng SIEM như IBM QRadar và giải pháp SOAR như Palo Alto Cortex XSOAR [1, 4], tương quan sự kiện bằng tập luật tĩnh và chạy kịch bản định sẵn. Bối trợ cho nhóm này là các kỹ thuật phân tách nhật ký trực tuyến kinh điển như Drain [31], giúp rút gọn cú pháp nhưng chưa thể phân tích ngữ cảnh hành vi. Qua phỏng vấn người vận hành SOC, AlAhmadi và cộng sự [3] ghi nhận chất lượng cảnh báo thấp là nguyên nhân hàng đầu gây nên tình trạng quá tải. Ưu thế cốt lõi của nhóm này là độ trễ rất thấp, đặc tính mà Tầng 1 của SENTINEL kế thừa và phát triển.

Nhóm thứ hai, tác tử phân loại có tăng cường truy xuất, tiêu biểu là CyberRAG [32], điều phối các bộ phân loại tinh chỉnh theo từng họ tấn công phía sau một tác tử LLM và công bố độ chính xác trên 94% trên các phép thử tấn công web. Công trình này giải quyết chất lượng phân tích cho những sự kiện đã chọn, nhưng thiếu tầng lọc tốc độ đường truyền ở đầu nguồn để quản lý lưu lượng lớn.

Nhóm thứ ba, đa tác tử và chú trọng quản trị, gồm AutoBnB-RAG [33], LanG [34] và Policy-Guided Threat Hunting [35]. AutoBnB-RAG đánh giá phản ứng sự cố trong môi trường mô phỏng trò chơi bàn *Backdoors & Breaches*. LanG dựng trên LangGraph với các điểm chốt duyệt thủ công và phòng thủ tiêm nhiễm hai lớp (biểu thức chính quy kết hợp Llama Prompt Guard 2 đạt F1 98,1%). Policy-Guided Threat Hunting sử dụng bộ tự mã hoá tái dựng và học tăng cường sâu hai lớp để tiền phân loại trước khi đưa vào LLM.

Khoảng trống nghiên cứu được xác định rõ ràng: phân tầng chi phí đã xuất hiện ở Policy-Guided Threat Hunting, phòng thủ tiêm nhiễm đã có ở LanG, và vận hành cục bộ đã được triển khai ở một số công trình. Tuy nhiên, chưa có kiến trúc đơn lẻ nào hợp nhất thành công: (1) giải quyết phần lớn lưu lượng ở tầng thống kê/học máy với độ trễ dưới 1 ms và tỷ lệ xả tải luôn đi kèm tỷ lệ tấn công nền của luồng dùng để đo; (2) suy luận có trạng thái chạy trên GPU cục bộ dưới quy tắc neo truy xuất nghiêm ngặt; và (3) bảo chứng phòng thủ

tiêm nhiễm dựa trên cấu trúc kết hợp với niêm phong pháp y HMAC-SHA256. Bảng 1 đối chiếu chi tiết SENTINEL với các nhóm giải pháp đại diện.

Bảng 1. Bảng so sánh đối chiếu giữa SENTINEL và các giải pháp phòng thủ hiện hành

Tiêu chí Đánh giá	SIEM / SOAR (QRadar, XSOAR)	Hệ tác tử LLM (CyberRAG, LanG, Policy-Guided)	Kiến trúc SENTINEL (Luận văn)
Kỹ thuật Cốt lõi	Tập luật tương quan tính, kịch bản Python/JS cứng	RAG tác tử, điều phối đa tác tử, phân loại sơ bộ bằng DRL	Bộ luật chữ ký Rule-based + Welford $\mathcal{O}(1)$ + LightGBM T1, LangGraph Agent T2
Mục tiêu Vận hành	Gom nhật ký tập trung và phản hồi theo kịch bản	Tự động hóa điều tra sự cố bằng suy luận ngôn ngữ	Giải quyết lưu lượng tại tầng rẻ, dành tầng đắt cho ca cần suy luận
Độ trễ & Phân tầng	Một tầng rẻ, không suy luận ngữ cảnh	Có ở một số công trình (DRL sơ bộ); chưa công bố tỷ lệ xả tải kèm tỷ lệ tấn công nền	Hai tầng: trung bình 0,182 ms ở T1; xả tải 97,5% lưu lượng trước T2 ở tỷ lệ tấn công nền 9,8%
Chủ quyền Dữ liệu	Cục bộ nội bộ	Triển khai cục bộ nhưng không ấn định giới hạn phần cứng nghiêm ngặt	Air-gapped 100% trên GPU cục bộ
Chống Prompt Inj.	Không áp dụng	Bộ phân loại xác suất (LanG: regex + Prompt Guard 2, F1 98,1%)	Bảo chứng cấu trúc Đóng gói Dữ liệu Phân định, độc lập với câu chữ payload
Kiểm toán Pháp y	Nhật ký văn bản tiêu chuẩn (dễ bị chỉnh sửa)	Có công bố nhật ký kiểm toán (LanG: mcp_audit.db); không niêm phong mật mã	Chuỗi HMAC-SHA256 phát hiện giả mạo vết chứng cứ

Chương 3

Thiết kế Hệ thống và Triển khai Kỹ thuật

Chương này trình bày phương pháp nghiên cứu, sau đó đi sâu chi tiết thiết kế và cài đặt thực nghiệm hệ thống SENTINEL, bao gồm: luồng xử lý hai tầng, bộ lọc tốc độ đường truyền và Cổng Học máy Tầng 1, tác tử nhận thức LangGraph và Bộ nhớ Đe dọa Tầng 2, cơ chế truy xuất tri thức lai Dual-RAG, cùng các giải pháp an ninh đối kháng AI kèm niêm phong kiểm toán mật mã.

3.1 Phương pháp Nghiên cứu

Luận văn tiếp cận theo phương pháp Nghiên cứu Khoa học Thiết kế (Design Science Research Methodology - DSRM) [36]. Đóng góp trung tâm của nghiên cứu là một hệ thống thực nghiệm (artefact), được đánh giá định lượng thông qua các thước đo thực nghiệm khách quan thay vì các lập luận cảm quan thuần túy. Hệ thống được cấu thành bởi ba trụ cột kỹ thuật chính:

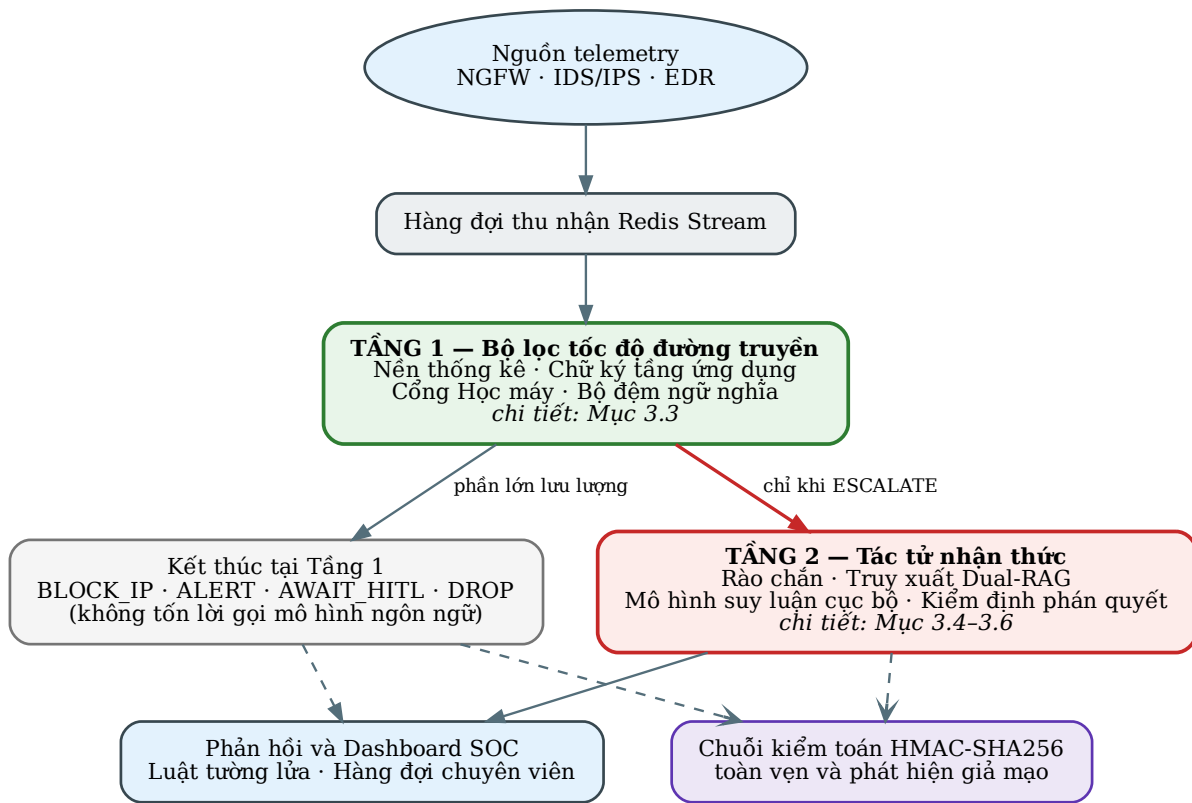
1. *Trụ cột luật tĩnh, thống kê và học máy*: Cung cấp năng lực lọc lưu lượng ở tốc độ đường truyền nhờ bộ luật chữ ký tầng ứng dụng (Rule-based), thuật toán thống kê trực tuyến Welford $\mathcal{O}(1)$ [16] kết hợp với Cổng Học máy LightGBM [17].
2. *Trụ cột logic tác tử*: Cung cấp năng lực suy luận ngữ cảnh sâu nhờ đồ thị trạng thái LangGraph [21] điều phối mô hình ngôn ngữ Foundation-Sec-8B-Instruct [19] vận hành cục bộ trên nền truy xuất lai FAISS/BM25/RRF [23–25].
3. *Trụ cột an ninh đối kháng*: Thiết lập ranh giới phòng thủ chắc chắn chống lại rủi ro tiêm nhiễm câu lệnh qua nhật ký [6, 8] và niêm phong vết chứng cứ bằng chuỗi mã hóa HMAC-SHA256 [29].

Hiệu lực vận hành của kiến trúc SENTINEL được đánh giá định lượng trên năm chiều đo lường cốt lõi: chất lượng phân loại sự cố, hiệu năng xử lý và thời gian phản hồi, khả năng kháng tấn công đối kháng, độ mạch lạc của lời giải thích an ninh (được chấm điểm độc lập bởi mô hình trọng tài), cùng tính toàn vẹn của hồ sơ kiểm toán pháp y. Toàn bộ các kết quả thực nghiệm, phân tích đối chứng và kiểm chứng giới hạn hệ thống sẽ được trình bày chi tiết tại Chương 4.

3.2 Kiến trúc Tổng thể SENTINEL và Tích hợp Ngăn xếp SOC

SENTINEL vận hành theo kiến trúc nhận thức hai tầng với nguyên lý cốt lõi là phân tách khối lượng công việc theo chi phí tính toán. Nhật ký thô từ các nguồn cảm biến vành ngoài được đẩy vào hàng đợi Redis Stream rồi chuyển tới Tầng 1. Tầng 1 đóng vai trò là chặng xử lý thống kê và học máy phi trạng thái, giải quyết phần lớn lưu lượng ở tốc độ đường truyền. Trong tập hành động của Tầng 1, chỉ duy nhất phán quyết ESCALATE được chuyển giao lên Tầng 2; các phán quyết còn lại (BLOCK_IP, ALERT, AWAIT_HITL, DROP) đều kết thúc xử lý ngay tại Tầng 1. Đây là căn cứ xác lập khái niệm tỷ lệ xả tải (offload rate) tại Chương 4: một sự kiện được tính là xả tải thành công khi không kích hoạt bất kỳ lời gọi suy luận mô hình ngôn ngữ nào.

Tại Tầng 2, tác tử LangGraph [21] tiến hành suy luận sâu theo ngữ cảnh trên mô hình chuyên biệt an ninh Foundation-Sec-8B-Instruct [19] (lượng tử hóa GGUF Q4_K_M), kết hợp trạng thái lịch sử từ Bộ nhớ Đe dọa và tri thức truy xuất từ Dual-RAG. Đầu ra được kiểm soát bởi rào chắn tắt định giới hạn trong 3 trạng thái cho phép (BLOCK_IP, LOG, AWAIT_HITL), với mọi bản ghi từ cả hai tầng đều được niêm phong mật mã bằng chuỗi HMAC-SHA256 [29]. Nhờ đó, SENTINEL đóng vai trò là tầng trung gian nhận thức (cognitive middleware) giữa SIEM và các giải pháp thực thi phòng thủ (NGFW/SOAR), giúp hấp thụ nhiều lưu lượng ở Tầng 1 và giải thích minh bạch cho các sự kiện leo thang ở Tầng 2, bảo đảm chủ quyền dữ liệu khi vận hành cách ly mạng (air-gapped) trên GPU cục bộ [7]. Sơ đồ luồng xử lý và mối liên kết giữa các thành phần được thể hiện chi tiết tại Hình 1.

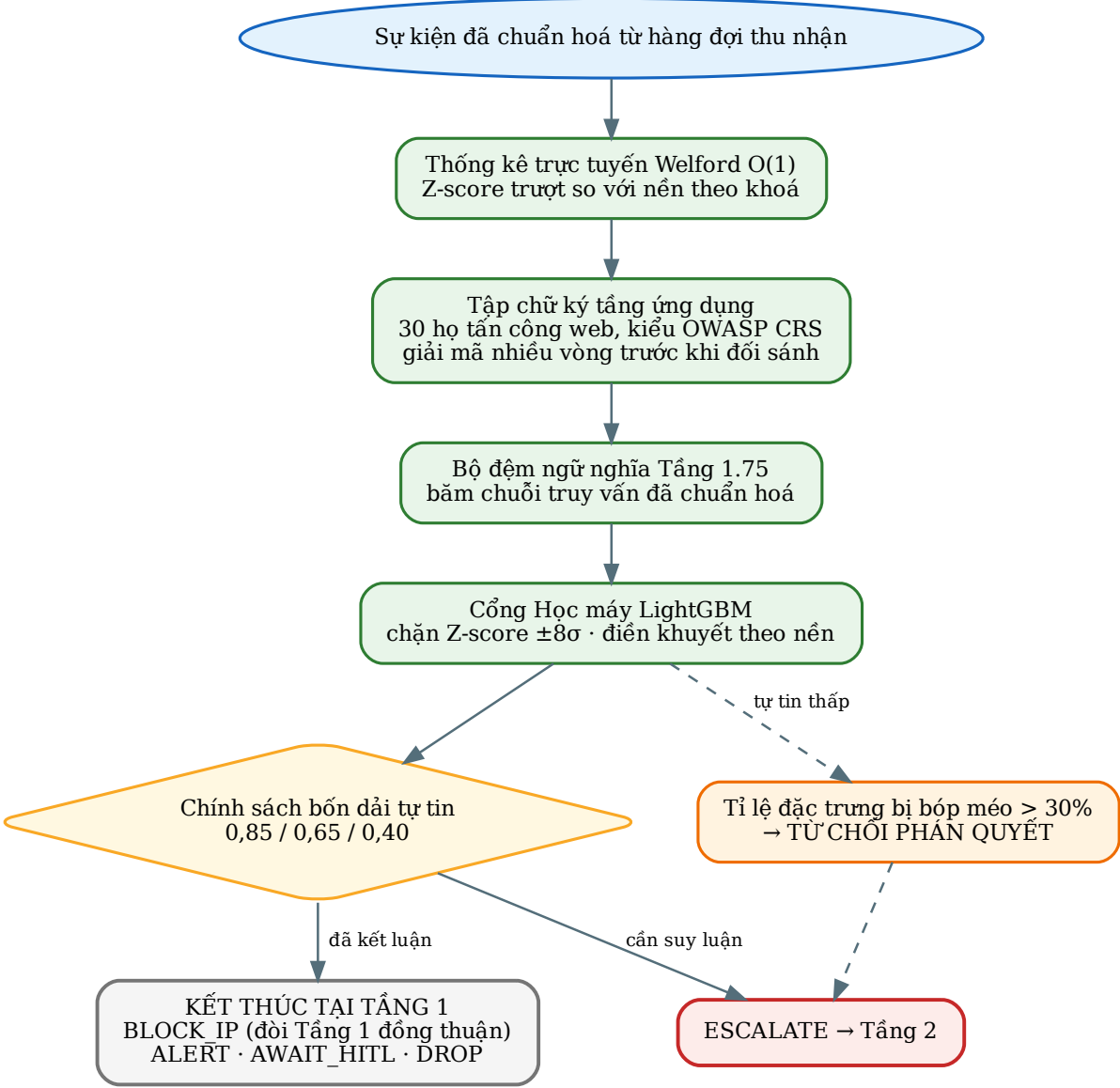


Hình 1. Sơ đồ kiến trúc tổng thể SENTINEL.

3.3 Tầng 1: Bộ lọc Tốc độ Đường truyền và Công Học máy

Tầng 1 vận hành như vành ngoài phi trạng thái tốc độ đường truyền, hợp nhất bộ chữ ký tầng ứng dụng và bộ lọc thống kê đường nền Welford $\mathcal{O}(1)$ [16] (Công thức 2.1). Tập chữ ký gồm 30 họ tấn công chuẩn hóa OWASP CRS 3.3 [37] (23 họ bao phủ OWASP Top 10:2021; 7 họ nhận diện bất thường mạng và điểm cuối như ransomware, đào tiền mã hóa). Song song đó, bộ lọc Welford tính toán Z-score tức thời $Z = (x - \mu) / \sigma$ trên các đặc trưng lưu lượng (tần suất gói tin, dung lượng luồng, thời lượng) và liên tục cập nhật tham số μ, σ để tự động loại bỏ lưu lượng lành tính. Sơ đồ luồng xử lý chi tiết tại Tầng 1 được thể hiện tại Hình 2.

Đối với lưu lượng lặp lại khối lượng lớn (DDoS, dò quét mật khẩu), Bộ đệm Ngữ nghĩa Tầng 1.75 băm chuỗi truy vấn trong RAM để tái sử dụng phán quyết trong < 1 ms mà



Hình 2. Sơ đồ chi tiết Tầng 1.

không cần tính toán lại.

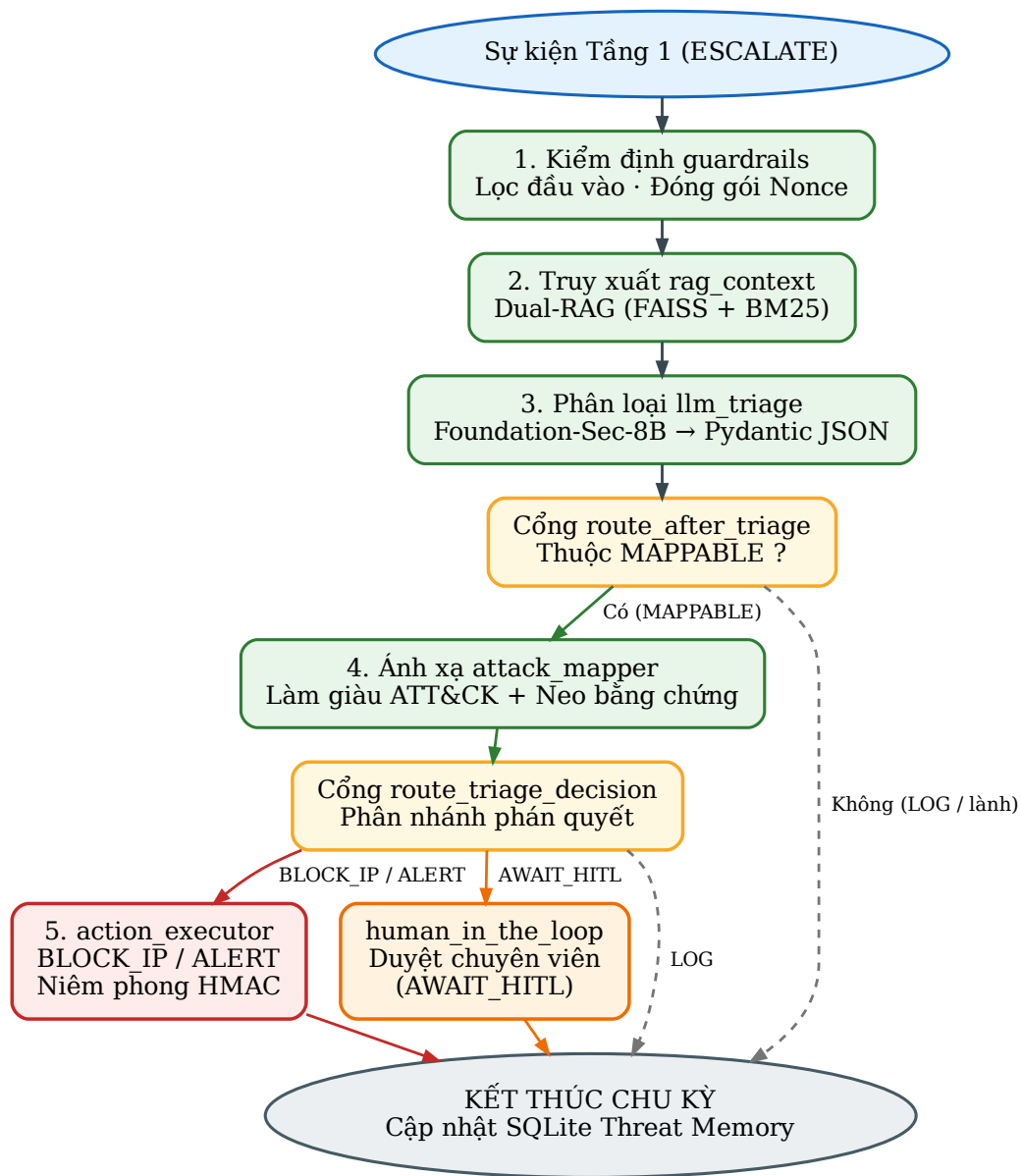
Tiếp nối là Cổng Học máy LightGBM [17], phân tích tương tác đặc trưng phi tuyến, huấn luyện trên 664.674 mẫu và kiểm thử trên 189.907 mẫu NetFlow trích từ bộ dữ liệu CSE-CIC-IDS2018 [9] gồm 949.535 bản ghi. Để chống né tránh đối kháng (anti-evasion), Cổng Học máy kẹp Z-score trong $[-8, 8]\sigma$, bù giá trị khuyết bằng trung bình đường nền, và tự động bỏ phiếu trắng (abstain) chuyển giao sự kiện lên Tầng 2 khi đặc trưng bị bóp méo vượt 30%. Các phán quyết ánh xạ theo chính sách 4 dải tự tin (0,85 / 0,65 / 0,40 cho BLOCK_IP / ESCALATE / ALERT / LOG), bảo đảm lệnh tự động chặn chỉ thi hành khi đạt độ tự tin cao nhất và có đồng thuận từ bộ lọc chữ ký.

3.4 Tầng 2: Tác tử Nhận thức LangGraph và Bộ nhớ Đe dọa

Tầng 2 vận hành mô hình an ninh Foundation-Sec-8B-Instruct [19] (GGUF Q4_K_M) phục vụ bởi engine llama.cpp biên dịch CUDA trên GPU cục bộ. Quy trình suy luận được điều phối bởi đồ thị LangGraph [21] qua các trạm xử lý: kiểm tra rào chắn (guardrails), bồi đắp ngữ cảnh (rag_context), phân loại sự cố (llm_triage), ánh xạ kỹ thuật (attack_mapper), và thi hành phán quyết (action_executor) hoặc chuyển duyệt thủ công (human_in_the_loop). Sơ đồ trạng thái tác tử thể hiện tại Hình 3.

Tại attack_mapper, nếu thiếu chứng cứ tri thức, sự cố tự động chuyển sang hàng đợi chuyên viên (AWAIT_HITL) thay vì phỏng đoán. Tại llm_triage, nhãn phân loại nội bộ được gỡ khỏi prompt để bảo đảm tính khách quan. Ngữ cảnh được tối ưu bằng thuật toán nén nhật ký Drain [31] kết hợp giám sát ngân sách token.

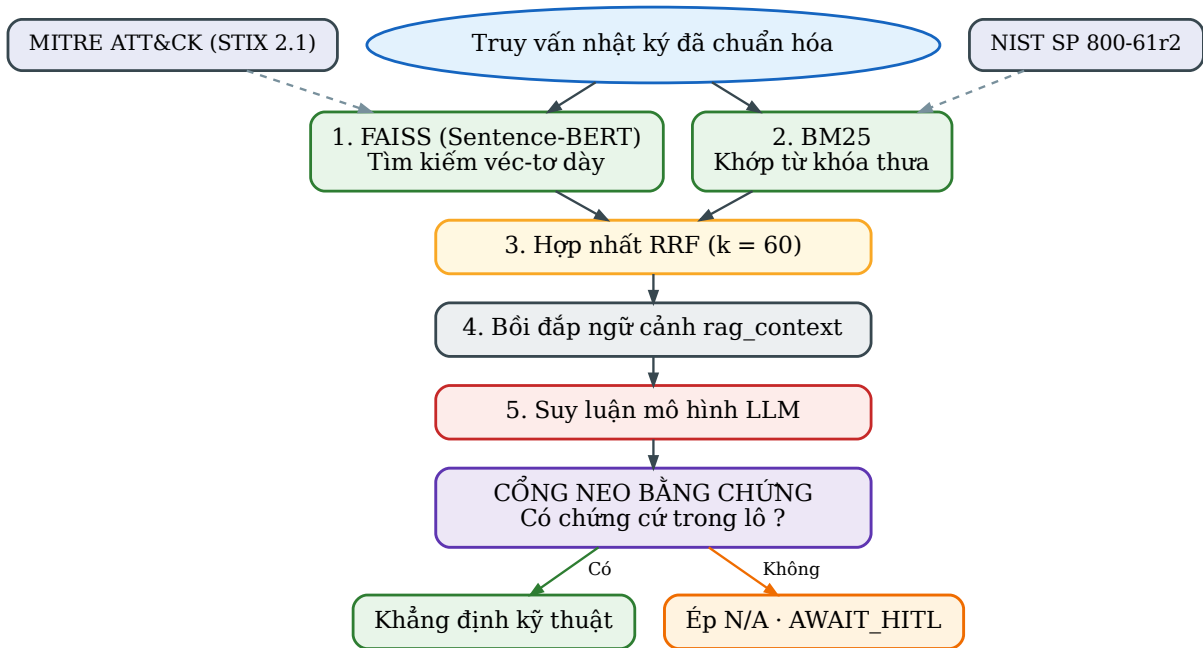
Để liên kết hành vi tấn công đa giai đoạn, Tầng 2 duy trì Bộ nhớ Đe dọa trên SQLite (chế độ rollback-journal tránh xung đột khóa Docker). Điểm uy tín S suy giảm theo thời gian im lặng t : $S_{\text{new}} = S_{\text{old}} \times (1 - \lambda)^t$ với λ là hệ số suy giảm. Khi $S = 100$, Tầng 1 áp dụng cơ chế chặn-ngay-khi-thấy (block-on-sight) vĩnh viễn mà không cần tái kích hoạt Tầng 2. Các thực thể hạ tầng nội bộ được bảo vệ bằng danh sách trắng (whitelist) nhằm triệt tiêu rủi ro tự gây từ chối dịch vụ (Self-DoS).



Hình 3. Đồ thị trạng thái tác tử Tầng 2.

3.5 Cơ chế Truy xuất Tri thức Lai Dual-RAG

Để triệt tiêu ảo giác, Tầng 2 truy xuất trên cơ sở tri thức gồm 433 mục MITRE ATT&CK (STIX 2.1) [26] và NIST SP 800-61r2 [27]. Đường ống song song kết hợp FAISS [23] (Sentence-BERT [38]) tìm véc-tơ dày theo ý đồ và BM25 [24] khớp từ khóa thừa cho mã CVE, cổng dịch vụ. Kết quả hợp nhất thứ hạng qua Reciprocal Rank Fusion (RRF, $k = 60$) [25] nạp vào nút rag_context (Hình 4).



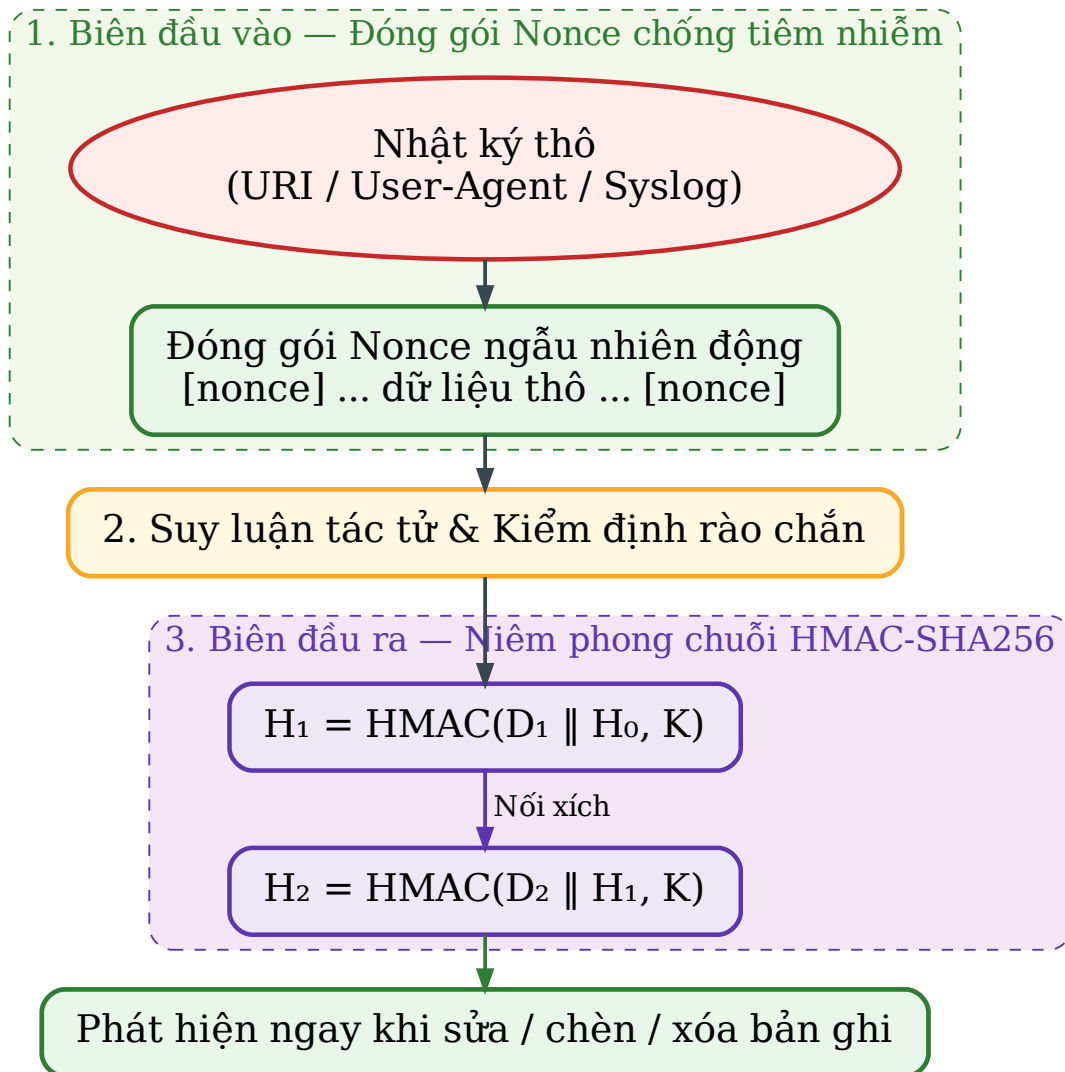
Hình 4. Sơ đồ truy xuất Dual-RAG và rào chắn neo bằng chứng.

Văn bản truy xuất được bộ khử độc RAG chuẩn hóa Unicode, loại bỏ thẻ HTML/Markdown và mệnh lệnh nhằm chặn tiềm nhiệm gián tiếp. Ở đầu ra, rào chắn neo bằng chứng đối chiếu ngược mã MITRE ATT&CK của mô hình với tài liệu trong lô. Nếu không xuất hiện trong chứng cứ, mã bị ép về N/A và chuyển sang hàng đợi AWAIT_HITL, để không mã kỹ thuật nào vắng mặt trong tài liệu truy xuất được đem ra thi hành.

3.6 An ninh Đối kháng AI và Niêm phong Kiểm toán Mật mã

Tấn công tiêm nhiễm câu lệnh qua nhật ký (Log Prompt Injection) [6, 8] nhúng chỉ thị điều khiển vào các trường nhật ký thô (User-Agent, URI). SENTINEL giải quyết bằng cơ chế Đóng gói Dữ liệu Phân định (Delimited Data Encapsulation) dùng chuỗi Nonce ngẫu nhiên sinh mới theo lô, ngăn chặn tấn công chèn ký tự thoát vùng bọc (Hình 5). Ba bộ thẩm định tất định bảo vệ ranh giới: Dữ liệu (loại nhật ký dị dạng), Quyết định (ép lược đồ Pydantic LLMDecision, từ chối chặn IP nội bộ), và Phản hồi (Zero Trust cho luật AI).

Về kiểm toán pháp y, mỗi bản ghi phán quyết D_i được liên kết chuỗi mật mã bằng HMAC-



Hình 5. Cơ chế đóng gói Nonce và chuỗi niêm phong HMAC.

SHA256 [29]:

$$H_i = \text{HMAC-SHA256}(D_i \parallel H_{i-1}, K) \quad (3.1)$$

với H_{i-1} là hash liền trước và K là khóa bí mật cục bộ. Hành vi chỉnh sửa, chèn hoặc xóa bản ghi sẽ làm phá vỡ tính liên tục chuỗi và bị phát hiện ngay lập tức, đảm bảo khả năng chống giả mạo bằng chứng.

Chương 4

Thực nghiệm và Đánh giá

Chương này trình bày kết quả đánh giá thực nghiệm hệ thống SENTINEL trên ba khía cạnh: hiệu năng xả tải lưu lượng, năng lực bảo vệ đối kháng AI kèm niêm phong mật mã, và chất lượng suy luận nhận thức tác tử. Thực nghiệm được thực hiện trên máy chủ cách ly mạng (Docker Compose, Intel Core i7, 32 GB RAM, GPU NVIDIA cục bộ chạy Foundation-Sec-8B-Instruct [19]). Tỷ lệ xả tải được đo trên 99.717 sự kiện có tỷ lệ tấn công nền 9,8%, tương thích với tỷ lệ đe dọa thực thấp đã ghi nhận tại các SOC vận hành [3]; chất lượng phân loại và rào chắn được đánh giá trên các tập chuẩn hóa (CSE-CIC-IDS2018 [9], CSIC 2010 [10], DAPT 2020 [11]) cùng 823 mẫu đối kháng [12–14, 39]. Mọi thước đo đều công bố mẫu số đo đặc tương ứng và tập trung trực tiếp vào giải đáp các câu hỏi nghiên cứu.

4.1 Hiệu năng Xả tải Lưu lượng và Kinh tế học Tầng lọc

Nút thắt cổ chai lớn nhất của việc ứng dụng Mô hình Ngôn ngữ Lớn (LLM) trong các Trung tâm Điều hành An ninh (SOC) là chi phí suy luận đắt đỏ và độ trễ tính toán lớn nếu phải xử lý từng sự kiện đơn lẻ. Để giải quyết thách thức này, kiến trúc SENTINEL được thiết kế dựa trên nguyên lý kinh tế học tầng lọc (Filtration Economics): “*giải quyết tất định các phán quyết rẽ trước khi leo thang lên tầng suy luận đắt*”. Theo định nghĩa tại Mục 3.2, một sự kiện được tính là xả tải (offloaded) thành công khi được xử lý trực tiếp ở các tầng lọc bên dưới mà không kích hoạt lời gọi mô hình LLM. Phép đo này tính gộp tất cả các hành động phán quyết cuối cùng bao gồm DROP, BLOCK_IP, ALERT và AWAIT_HITL, bởi tất cả đều không phát sinh chi phí suy luận token.

Kết quả thực nghiệm trên luồng vận hành dạng SOC gồm 99.717 sự kiện ở tỷ lệ tấn công

nền 9,8% chứng minh khả năng cắt giảm khối lượng tính toán của SENTINEL. Hệ thống xả tải thành công 97,5% tổng lưu lượng (loại bỏ 97.199 lời gọi LLM), chỉ đẩy 2,5% (2.518 sự kiện) lên Tầng 2 để suy luận nhận thức. Bảng 2 tổng hợp chi tiết cơ chế kỹ thuật, độ xả tải, độ trễ trung bình và hiệu quả tiết kiệm tài nguyên theo từng tầng xử lý của hệ thống.

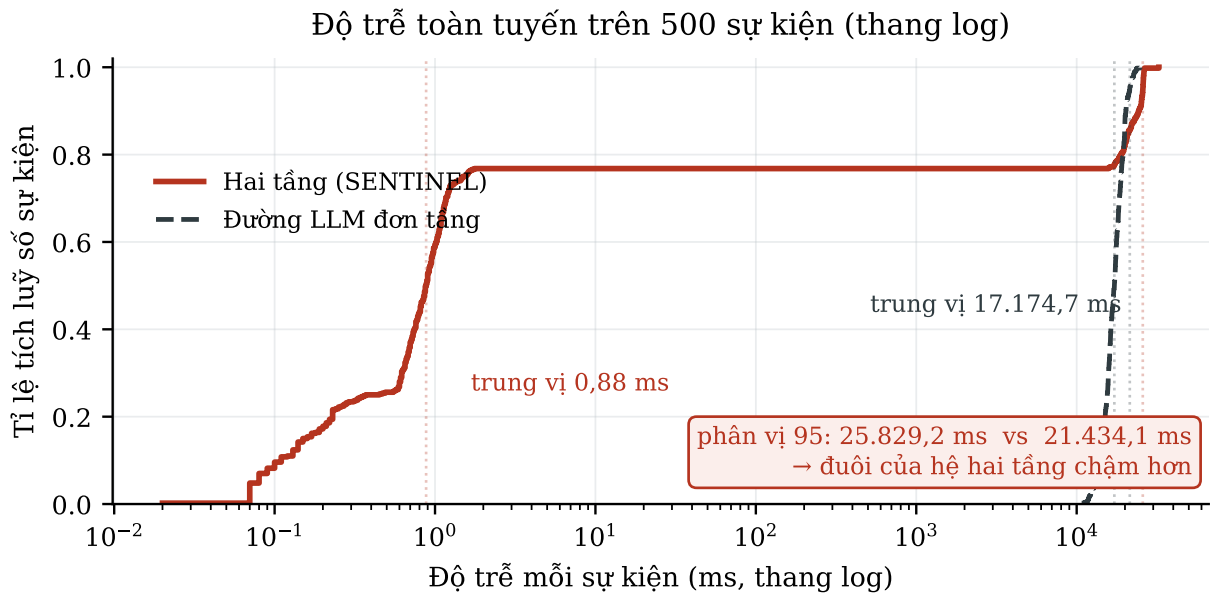
Bảng 2. Chi tiết cơ chế kỹ thuật và hiệu quả xả tải theo từng tầng xử lý của SENTINEL trên luồng dạng SOC (99.717 sự kiện)

Tầng xử lý	Cơ chế kỹ thuật	Độ xả tải	Độ trễ trung bình	Hiệu quả tiết kiệm tài nguyên
Tầng 1 (Luật và Welford)	Luật WAF tĩnh + Thống kê Z-score $O(1)$	38,3% (38.207 sk)	0,182 ms	0 token LLM, 0 GPU VRAM
Cổng Học máy	Phân loại LightGBM (MCC 0,667)	59,2% (58.992 sk)	0,287 ms	Loại bỏ 58.992 lời gọi LLM; 0 FP trên 962 lệnh tự chặn
Bộ đệm Ngữ nghĩa (Tầng 1.75)	Khớp chính xác đầu vào tải trọng HTTP; tỷ lệ trúng đệm, không phải phân xả tải luồng	81,3% (1.220/1.500)	9,8 ms	Tăng tốc 8,9× cho truy vấn trùng lặp
Tầng 2 (Tác tử LLM)	LangGraph + Dual-RAG MITRE ATT&CK	2,5% (2.518 sk)	13.438 ms	Gom 95,0% đe dọa vào 15,76% tải (giảm 84,24% tải chuyên viên)
Cộng dồn (Hệ thống)	Kiến trúc phân tầng hai tầng	97,5% (97.199 sk)	Trung vị: 0,88 ms	Loại bỏ 97.199 lời gọi LLM (nhanh hơn 20.531× thuần LLM)

Cơ chế xả tải phân tầng vận hành thông qua sự phối hợp chặt chẽ giữa các thành phần kỹ thuật. Tầng 1 sử dụng bộ luật chữ ký tĩnh kết hợp với thuật toán thống kê Welford $O(1)$ [16] để giải quyết 38,3% lưu lượng với độ trễ trung bình 0,182 ms mà không tiêu tốn tài nguyên GPU; phần này gồm 31.012 sự kiện lành tính và 7.195 sự kiện tấn công cường độ cao. Cổng Học máy LightGBM [17] đóng vai trò bộ lọc trung gian, xử lý mỗi vector đặc trưng 76 chiều trong 0,287 ms (thông lượng 3.452 sự kiện/giây) và xả tải thêm 59,2% lưu lượng lành tính. Đánh giá trên tập datatest.json (4.236 sự kiện gồm đặc trưng luồng và tải trọng HTTP web), Cổng đạt MCC 0,667 và độ chính xác cân bằng 0,833 trên 2.534 sự kiện Cổng trực tiếp phán quyết, cùng precision 100% (0 báo động giả) trên 962 lệnh tự động chặn (BLOCK_IP). Đối với các sự kiện lặp lại, Bộ đệm Ngữ nghĩa Tầng 1.75 giải quyết 81,3% truy vấn với hệ số tăng tốc 8,9×. Nhờ đó, Tầng 2 chỉ phải xử lý 2,5% số sự kiện

phức tạp còn lại, giúp gom 95,0% mỗi đe dọa thực sự vào 15,76% khối lượng làm việc và cắt giảm 84,24% lượng thông tin chuyên viên SOC phải phân tích.

Đánh giá độ trễ toàn tuyến trên 500 sự kiện lấy mẫu theo bước cố định cho thấy độ trễ trung bình giảm từ 17.187,9 ms xuống 5.286,7 ms (mức giảm 69,2%; kiểm định Mann–Whitney U , $p \approx 9 \times 10^{-57}$). Độ trễ trung vị giảm từ 17.174,7 ms xuống còn 0,88 ms (rút ngắn gần 19.500 lần) do phần lớn sự kiện lành tính được giải quyết dưới 1 ms ngay tại Tầng 1. Bách phân vị thứ 95 (P_{95}) ghi nhận 25.829 ms (so với 21.434 ms ở mô hình đơn tầng) do các sự kiện leo thang phải đi qua các lớp lọc trước khi tới mô hình ngôn ngữ, thể hiện qua đường phân phối tích lũy độ trễ (ECDF) tại Hình 6.



Hình 6. Phân phối tích lũy độ trễ (ECDF) trên 500 sự kiện kiểm thử.

So sánh thông lượng trên tập phân tầng 150 sự kiện đại diện cho lưu lượng lành tính, tấn công mạng và tấn công web (Bảng 3) cho thấy SENTINEL đạt thông lượng 3.860 sự kiện/giây, nhanh hơn $20.531 \times$ so với cấu hình đơn tầng thuần LLM (0,19 sự kiện/giây).

Bảng 3. So sánh thông lượng giữa SENTINEL và các cấu hình đối chứng trên 150 sự kiện

Cấu hình đối chứng	Thông lượng (sk/giây)
H1 — Chữ ký tĩnh (30 họ WAF)	11.129
SENTINEL — Tầng 1 + Cổng Học máy	3.860
H2 — LightGBM đơn tầng (ngưỡng phẳng)	2.162
H3 — LLM đơn tầng (cùng dữ liệu, mô hình, prompt)	0,19

4.2 Rào chắn An ninh Đối kháng AI và Toàn vẹn Kiểm toán Mật mã

Đánh giá an ninh đối kháng của SENTINEL được thực hiện trên hai bề mặt tấn công cốt lõi: tiêm nhiễm câu lệnh qua không gian ngôn ngữ (prompt injection) và thao túng vector đặc trưng ở không gian số (feature-space evasion). Tại Tầng 1, hệ thống triển khai lớp lọc chữ ký tĩnh sơ cấp gồm ba bộ dò song song (đối sánh dấu hiệu mẫu, trung hòa mã hóa và cô lập ký tự phân định) để phát hiện sớm các chỉ thị độc hại. Lớp lọc này được đánh giá trên 823 mẫu tiêm nhiễm ngôn ngữ chuẩn hóa thu thập từ ba kho dữ liệu công bố quốc tế gồm AdvBench [12], deepset [13] và jackhhao [14], bổ sung các biến thể vượt rào DAN [39]. Kết quả thực nghiệm ghi nhận lớp lọc tĩnh ngăn chặn 18,8% (132/703 mẫu) thuộc kho công bố và đạt 72,5% (58/80 mẫu) trên tập do tác giả biên soạn chuyên biệt cho các kỹ thuật che giấu phức tạp. Khi kiểm thử đối chứng âm trên 230 nhật ký lành tính, lớp lọc ghi nhận 46 cảnh báo nhầm (tương ứng tỷ lệ 20,0%); toàn bộ 46 cảnh báo nhầm này đều xuất phát từ bộ dò mã hóa và chỉ mang tính chất chú thích bổ sung thông tin cho bản ghi chứ không từ chối phục vụ (DoS) hay làm gián đoạn lưu lượng hợp lệ. Bảng 4 tổng hợp chi tiết kết quả đánh giá các lớp rào chắn an ninh đối kháng và niềm phong mật mã.

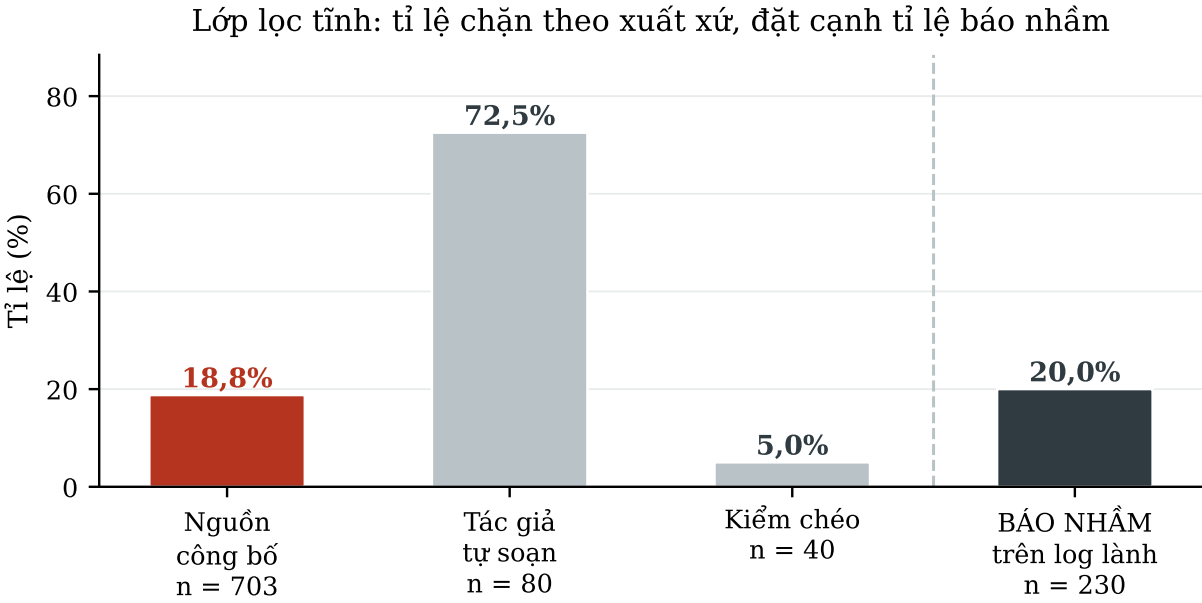
Bảng 4. Các lớp rào chắn an ninh đối kháng, mẫu số đánh giá và kết quả phòng thủ, kể cả niềm phong mật mã

Lớp rào chắn & Bề mặt tấn công	Mẫu số đo đạc	Kết quả phòng thủ
Lọc tĩnh Tầng 1 (Kho mẫu công bố)	703 mẫu	18,8% (132/703)
Lọc tĩnh Tầng 1 (Mẫu tác giả biên soạn)	80 mẫu	72,5% (58/80)
Lọc tĩnh Tầng 1 (Đối chứng nhật ký lành tính)	230 nhật ký lành tính	20,0% báo nhầm (chú thích)
Cổng Học máy (Né tránh đặc trưng cực trị)	1.036 mẫu tấn công	98,75% (1.023/1.036)
Cổng Học máy (Bỏ phiếu trắng khi đặc trưng méo)	4.236 sự kiện	116 sự kiện leo thang T2
Đóng gói Dữ liệu Phân định Tầng 2 (Kháng tiêm nhiễm)	678 mẫu leo thang	100,0% (678/678)
Đóng gói Dữ liệu Phân định Tầng 2 (4 vị trí trường)	100 mẫu công bố	100,0% (24/24, 23/23, 30/30, 23/23)
Kiểm tra lược đồ Pydantic (Lỗi backend ép phát sinh)	1 lỗi tạo chủ động	AWAIT_HITL (không sập)
Niềm phong HMAC-SHA256 (3 kịch bản giả mạo)	30 lượt thử/kiểu	100,0% phát hiện giả mạo
Niềm phong HMAC-SHA256 (Nhật ký nguyên vẹn)	450 bản ghi	0 báo động giả

Đối với 678 mẫu đối kháng phức tạp leo thang qua Tầng 1 (bao gồm 543 mẫu thực sự vượt rào), hệ thống chuyển giao lưu lượng cho Tầng 2 xử lý. Thay vì dựa vào mô hình phân loại xác suất vốn luôn tồn tại điểm mù trước các mẫu tấn công mới, Tầng 2 áp dụng cơ chế bảo chứng cấu trúc Đóng gói Dữ liệu Phân định (Delimited Data Encapsulation). Cơ chế này nhúng nhật ký thô vào môi trường cô lập tất định bằng các ranh giới ngẫu nhiên duy nhất, ngăn chỉ thị nhúng trong dữ liệu ghi đè chỉ thị hệ thống của LLM. Đánh giá trên toàn bộ 678 mẫu leo thang (độ phủ 100%), Tầng 2 đạt tỷ lệ vô hiệu hóa 100% (678/678 mẫu), chặn toàn bộ các nỗ lực chiếm quyền tác tử trong phạm vi tập mẫu này. Kiểm thử theo vị trí trên 100 mẫu phân bố ở bốn trường dữ liệu (URI, User-Agent, message, payload) đều ghi nhận tỷ lệ bảo vệ 100%. Trường hợp backend bị ép phát sinh lỗi cấu trúc, trình kiểm soát Pydantic tự động đưa tác tử về trạng thái an toàn `AWAIT_HITL` mà không gây sập hệ thống.

Ở bề mặt tấn công né tránh không gian đặc trưng số (feature-space evasion), 1.036 mẫu tấn công trích từ hai tập dữ liệu chuẩn CSE-CIC-IDS2018 [9] và CSIC 2010 [10] được làm méo đặc trưng ở mức cực trị để kiểm thử Cổng Học máy LightGBM. Cổng áp dụng cơ chế kẹp giá trị Z-score ($\pm 8\sigma$) và chính sách bỏ phiếu trắng (abstain) khi có hơn 30% số đặc trưng vượt 6σ . Kết quả cho thấy 98,75% số mẫu (1.023/1.036 mẫu) vẫn bị giữ nguyên phân loại độc hại, đồng thời tự động chuyển giao 116 sự kiện nghi vấn (từ tập 4.236 sự kiện web/flow) lên Tầng 2 để suy luận sâu. Hình 7 thể hiện tỷ lệ chặn của lớp lọc tĩnh theo nguồn mẫu bên cạnh tỷ lệ báo nhầm trên nhật ký lành tính.

Song song với rào chắn đối kháng, tính toàn vẹn nhật ký phục vụ điều tra pháp y an ninh mạng được bảo đảm bằng chuỗi băm mật mã HMAC-SHA256 liên kết nối tiếp, trong đó mỗi bản ghi tự động liên kết với giá trị băm của bản ghi liền trước. Thử nghiệm trên 30 kịch bản tấn công giả mạo cho từng dạng xâm phạm (sửa đổi nội dung bản ghi, chèn bản ghi giả và xóa bản ghi ở giữa) ghi nhận tỷ lệ phát hiện chính xác 100% vị trí bị sai lệch mà không phát sinh báo động giả nào trên 450 bản ghi nguyên vẹn. Cơ chế này đảm bảo chống chối bỏ và giữ nguyên giá trị chứng cứ pháp y cho toàn bộ dữ liệu nhật ký hệ thống.



Hình 7. Tỷ lệ chặn của lớp lọc tĩnh theo nguồn mẫu và tỷ lệ báo nhảm trên nhật ký lạnh tính.

4.3 Suy luận Nhận thức Tác tử và Quy kết Kỹ thuật Tấn công

Năng lực suy luận nhận thức tác tử và quy kết kỹ thuật tấn công theo khung MITRE ATT&CK của SENTINEL được đánh giá trên tập dữ liệu gồm 500 mẫu tải trọng HTTP (trích từ CSIC 2010 [10], bao gồm 250 mẫu có nhãn tấn công ứng dụng web và 250 mẫu tải trọng lạnh tính). Đánh giá chặng truy xuất cho thấy module tri thức lai Dual-RAG (kết hợp FAISS tìm kiếm ngữ nghĩa và BM25 tìm kiếm từ khóa RRF) đạt trần truy xuất chính xác 80,0% (200/250 mẫu) ở cấp kỹ thuật, với chỉ số Hit@3 đạt 0,93 đo trên 243 mẫu có leo thang. Tuy nhiên, khi đi qua toàn tuyến tác tử Tầng 2, độ chính xác quy kết ghi nhận 68,0% (170/250 mẫu, với độ chính xác cấp chiến thuật đạt 70,4% và độ trễ trung vị 13.293 ms). Khoảng cách 12,0 điểm phần trăm từ chặng truy xuất đến phán quyết toàn tuyến xuất phát từ cơ chế rào chắn neo bằng chứng (evidence-anchoring guardrail): rào chắn này đã ép 22 trong 30 mẫu bị mất về trạng thái N/A do mã kỹ thuật đề xuất không hiện diện trong tập tài liệu được truy xuất. Đây là sự đánh đổi kiến trúc có chủ ý: ưu tiên bảo chứng chỉ phát ra mã kỹ thuật hiện diện trong tập chứng cứ đã truy xuất, thay vì phán quyết thiếu căn cứ. Bảng 5 tổng hợp độ chính xác quy kết và trần truy xuất cho từng kỹ thuật.

Bảng 5 chỉ ra hai dạng thất bại có bản chất khác nhau, đồng thời cung cấp căn cứ thực

Bảng 5. Đánh giá độ chính xác quy kết kỹ thuật MITRE ATT&CK và trần truy xuất RAG (quy kết trên 250 mẫu có nhãn; truy xuất trên 243 mẫu có leo thang)

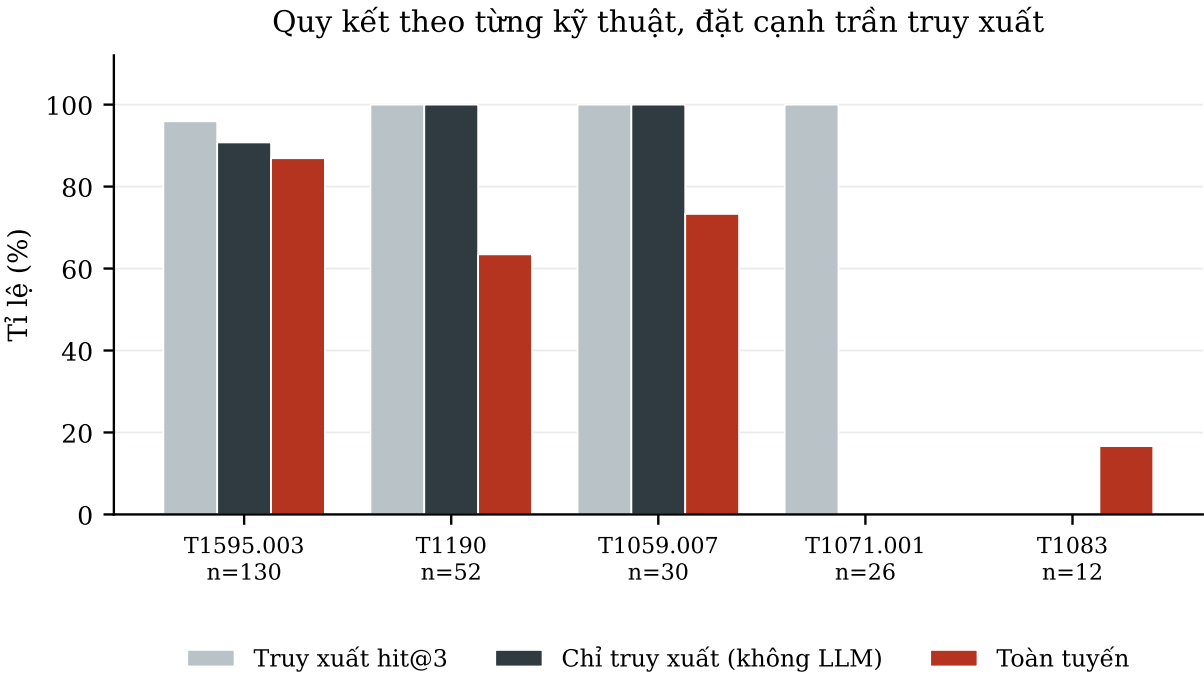
Kỹ thuật ATT&CK	<i>n</i>	Hit@3	Chỉ RAG	Toàn tuyến
T1190 (Khai thác ứng dụng công khai)	52	1,00	100,0%	63,5%
T1059.007 (Thực thi JavaScript)	30	1,00	100,0%	73,3%
T1595.003 (Dò quét từ điển)	130	0,96	90,8%	86,9%
T1083 (Dò tìm tệp và thư mục)	12	0,00	0,0%	16,7%
T1071.001 (Giao thức Web)	26	1,00	0,0%	0,0%
Trung bình toàn bộ kỹ thuật	250	0,93	80,0%	68,0%

nghiệm giải trình khoảng lệch 12,0 điểm phần trăm giữa trần truy xuất RAG (80,0%) và độ chính xác quy kết toàn tuyến (68,0%). Khoảng cách này được phân rã thành ba nguyên nhân kỹ thuật cụ thể:

Thứ nhất, vai trò của rào chắn neo bằng chứng (Evidence-Anchoring Guardrail) trong việc triệt tiêu ảo giác kỹ thuật: trong số 30 mẫu không quy kết thành công, có 22 mẫu (chiếm 73,3% số ca suy giảm độ chính xác) xuất phát từ việc tác tử đề xuất một mã kỹ thuật hợp lý theo tri thức tham số nội tại nhưng mã này hoàn toàn vắng mặt trong tập tài liệu RAG đã neo vào ngữ cảnh. Thay vì cho phép mô hình tự do suy diễn ngoài ngữ cảnh, rào chắn bảo vệ cưỡng chế chuyển phán quyết về N/A và định tuyến sang hàng đợi hoãn duyệt (AWAIT_HITL). Đây là sự đánh đổi kiến trúc có chủ ý: chấp nhận hy sinh 8,8 điểm phần trăm độ chính xác tự động danh nghĩa để bảo chứng rằng 100% các phán quyết kỹ thuật được ban hành đều có chứng cứ đối soát truy nguyên, triệt tiêu rủi ro cấu hình sai tường lửa do hiện tượng ảo giác AI;

Thứ hai, hiện tượng nhập nhằng phân cấp đa nhãn (hierarchical multi-label ambiguity) trong phân loại tải trọng web: các mẫu tấn công tải trọng HTTP (trích từ CSIC 2010) như tiêm lệnh SQL hay tấn công XSS đồng thời thỏa mãn đặc trưng của cả kỹ thuật khai thác ứng dụng công khai (T1190) lẫn thực thi mã kịch bản phía máy khách hoặc hệ thống (T1059.007). Module RAG truy xuất đồng thời cả hai tài liệu tham chiếu, nhưng tập nhãn chuẩn đối chiếu chỉ ghi nhận một nhãn đơn lẻ; khi tác tử lựa chọn mã kỹ thuật đồng hành còn lại, hệ thống ghi nhận là không trùng khớp theo tiêu chuẩn so khớp đơn nhãn tuyệt đối, dẫn đến độ chính xác toàn tuyến của T1190 đạt 63,5% và T1059.007 đạt 73,3%;

Thứ ba, sự phân hóa về độ phủ tri thức và vị trí xếp hạng tài liệu: đối với kỹ thuật T1083 (Dò tìm tệp và thư mục, $n = 12$), module RAG đạt Hit@3 bằng 0,00 do tri thức tương ứng chưa được bao phủ trong kho dữ liệu mẫu, dẫn đến việc tác tử không có căn cứ tài liệu để phán quyết. Ngược lại, với kỹ thuật T1071.001 (Giao thức Web), tài liệu đúng luôn được truy xuất nhưng chỉ đứng hạng ba theo trung vị, nên điểm số hòa trộn RRF không đủ để đưa tài liệu lên vị trí ưu tiên cao nhất, dẫn tới việc phép khớp chính xác thất bại ở cả chặng truy xuất lẫn toàn tuyến (0,0% ở cả hai): đây là lỗi ánh xạ ngữ cảnh chứ không phải lỗi độ phủ tri thức. Hình 8 so sánh trần truy xuất RAG với độ chính xác quy kết toàn tuyến.

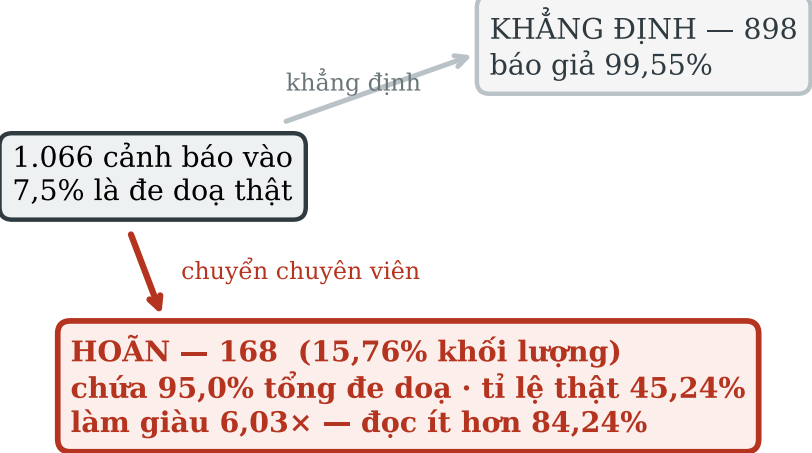


Hình 8. Độ chính xác quy kết theo từng kỹ thuật đối chiếu với trần truy xuất RAG.

Tầng 1 leo thang 1.066 cảnh báo tới Tầng 2, trong đó có 80 đe dọa thực sự (mật độ đe dọa nền 7,5%). Nhờ cơ chế phân luồng nhận thức, tác tử Tầng 2 chủ động chuyển 168 cảnh báo (chiếm 15,76% lưu lượng đầu vào) vào hàng đợi hoãn phán quyết (AWAIT_HITL). Hàng đợi này chứa 76 trên 80 đe dọa thực sự, tương ứng độ bao phủ 95,0% với precision 45,24%, tức làm giàu $6,03\times$ so với đầu vào. Cơ chế này giúp chuyên viên an ninh SOC cắt giảm 84,24% khối lượng tài liệu phải phân tích mà vẫn kiểm soát được 95,0% mỗi đe dọa thực tế. Hình 9 thể hiện phễu phân loại cảnh báo tại Tầng 2.

Chất lượng suy luận của tác tử Foundation-Sec-8B-Instruct được đánh giá trên 1.052 sự

Phân loại cảnh báo ở Tầng 2: giá trị nằm ở kênh hoãn, không ở phán quyết



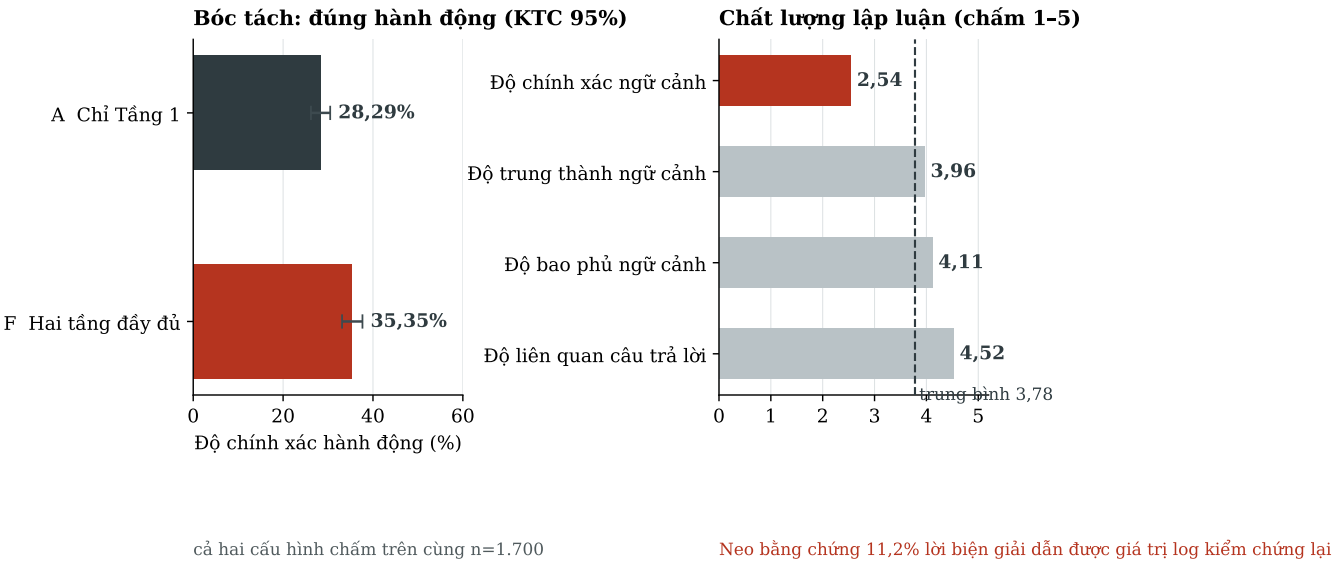
Hình 9. Phân loại cảnh báo tại Tầng 2 đối chiếu kênh khẳng định và hoãn.

kiện leo thang theo bốn trục RAGAS [40] bởi mô hình trọng tài khác họ Meta-Llama-3-8B-Instruct, đúng quy trình khuyến nghị nhằm tránh thiên lệch tự đề cao [41]. Kết quả ghi nhận điểm trung bình đạt 3,78/5,0 (với độ liên quan câu trả lời 4,52, độ bao phủ ngữ cảnh 4,11, độ trung thành 3,96 và độ chuẩn xác ngữ cảnh 2,54). Ngược lại, tỷ lệ neo bằng chứng trực tiếp chỉ đạt 11,2% (KTC 95% 9,5–13,3%): chưa tới một phần tám lời biện giải dẫn ra được giá trị log đối chiếu ngược với bản ghi, tức mức trần minh bạch của tầng giải thích.

Điểm số độ chuẩn xác ngữ cảnh (Context Precision đạt 2,54/5,0) tương đối thấp hơn so với độ bao phủ ngữ cảnh (Context Recall đạt 4,11/5,0) phản ánh ba nguyên nhân kiến trúc và dữ liệu cốt lõi: Thứ nhất, tính chất không đồng nhất của kho tri thức kép Dual-RAG: hệ thống đồng thời tích hợp cả kho kỹ thuật tấn công MITRE ATT&CK và cẩm nang ứng cứu sự cố NIST SP 800-61r2. Khi mô hình trọng tài đánh giá tác vụ quy kết nhãn kỹ thuật MITRE, toàn bộ các đoạn văn bản NIST (hướng dẫn giai đoạn ngăn chặn, khắc phục sự cố) và các kỹ thuật MITRE phụ trợ lân cận bị trọng tài đánh giá là văn bản không chứa nhãn đích trực tiếp, làm giảm tỷ lệ tín hiệu trên nhiễu của ngữ cảnh tổng hợp; Thứ hai, chiến lược ưu tiên độ bao phủ (Recall-Oriented Policy) trong an ninh mạng: trong môi trường vận hành SOC, hậu quả của việc bỏ sót đe dọa (False Negative) do RAG không thu hồi đủ chứng cứ nghiêm trọng hơn rất nhiều so với việc nạp dư thừa thông tin tham chiếu. Cấu hình tìm kiếm lai RRF chủ động chấp nhận giảm độ tinh khiết ngữ cảnh nhằm duy trì tỷ lệ bao phủ ngữ cảnh ở mức cao (4,11/5,0 tương đương 82,2%), giao phó vai trò sàng lọc

thông tin cho cơ chế chú ý (attention) của mô hình ngôn ngữ Tầng 2; Thứ ba, hiện tượng trùng lặp từ khóa giao thức (lexical overlap) trong thuật toán BM25: các bản ghi nhật ký an ninh mạng có mật độ lặp lại rất cao của các chuỗi ký tự định danh chuẩn (HTTP, POST, mã trạng thái 200, tên giao thức). Nhánh BM25 khi hòa trộn vào điểm RRF thường kéo theo các tài liệu kỹ thuật có chung giao thức vận chuyển nhưng khác biệt về tính chất chiến thuật.

Đánh giá bóc tách thành phần (ablation study) trên 1.700 mẫu thực nghiệm cho thấy hệ hai tầng đầy đủ đạt độ chính xác hành động 35,35% (KTC 95% 33,12–37,66), vượt trội rõ rệt so với mức 28,29% (KTC 95% 26,20–30,48) của cấu hình chỉ có Tầng 1. Cấu hình Tầng 1 đơn lẻ đạt độ chính xác tự quyết 69,01% nhưng bỏ ngỏ 59,00% sự kiện mà không thể xử lý, trong khi hệ thống đầy đủ không bỏ ngỏ sự kiện nào, đổi lại độ chính xác tự quyết giảm còn 57,72% so với 69,01%, với 55,24% phán quyết tự động và 44,76% hành động hoãn tường minh. Hình 10 so sánh độ chính xác hành động với bốn trục đánh giá RAGAS.



Hình 10. Đánh giá độ chính xác hành động bóc tách thành phần và bốn trục RAGAS.

4.4 Phân tích Khả năng Mở rộng Hạ tầng (Scalability Analysis)

Mặc dù toàn bộ phép đo thực nghiệm trong nghiên cứu này được thu thập trên máy trạm đơn GPU (Single-GPU Workstation), kiến trúc hai tầng của SENTINEL được thiết kế có chủ đích nhằm bảo đảm tính khả thi khi mở rộng quy mô lên lưu lượng nhật ký thực tế của doanh nghiệp, vốn có thể đạt ngưỡng hàng tỷ sự kiện mỗi ngày.

Về mặt định lượng, một hệ thống giám sát an ninh xử lý 1 tỷ sự kiện/ngày tương đương với thông lượng trung bình ≈ 11.574 sự kiện/giây, với các đỉnh tải có thể dao động từ 30.000 đến 50.000 sự kiện/giây trong các đợt bão tấn công (DDoS hoặc quét cổng diện rộng). Khả năng mở rộng của hệ thống được bảo chứng qua ba tầng kiến trúc:

Thứ nhất, tính chất phi trạng thái (stateless) và hiệu năng tính toán tuyến tính của Tầng 1: các cơ chế lọc chữ ký tĩnh, thuật toán Welford $\mathcal{O}(1)$ và Cổng Học máy LightGBM hoàn toàn vận hành trên CPU với chi phí 0 MB GPU VRAM. Với thông lượng đo đạc thực tế đạt 3.860 sự kiện/giây trên một lõi CPU đơn lẻ, việc xử lý thông lượng trung bình 11.574 sự kiện/giây chỉ đòi hỏi 3 đến 4 lõi tính toán CPU chạy song song thông qua cơ chế phân vùng hàng đợi (Kafka Consumer Group hoặc Kubernetes Horizontal Pod Autoscaler). Khi chuyển đổi Tầng 1 sang các ngôn ngữ lập trình hệ thống (như Rust hoặc Go kết hợp cơ

chế nhân mạng DPK), thông lượng một máy chủ đơn lẻ hoàn toàn có thể vượt ngưỡng 100.000 sự kiện/giây.

Thứ hai, hiệu ứng giảm tải theo cấp số nhân của nguyên lý Kinh tế học Tầng lọc và bộ nén Drain3: nhờ tỷ lệ xả tải 97,5% tại Tầng 1, lưu lượng leo thang lên Tầng 2 được kiểm chế xuống còn 2,5%, tức khoảng 25 triệu sự kiện/ngày (≈ 289 sự kiện/giây). Tiếp đó, thuật toán gom cụm mẫu nhật ký Drain3 tại Tầng 2 thực hiện nén các luồng log có cấu trúc lặp lại với hệ số nén từ $10\times$ đến $50\times$. Do đó, số lượng sự kiện thực sự đòi hỏi lời gọi suy luận nhận thức LLM sâu chỉ còn dao động trong khoảng từ 6 đến 25 sự kiện/giây.

Thứ ba, lộ trình chuyển đổi Tầng 2 từ máy trạm đơn GPU lên cụm hạ tầng doanh nghiệp: môi trường thực nghiệm đơn GPU vận hành suy luận tuần tự qua `llama.cpp` là cấu hình tối thiểu phục vụ kiểm chứng khái niệm (Proof of Concept, thông lượng 0,2 – 0,5 sự kiện/giây). Để đáp ứng mức tải 6 đến 25 sự kiện/giây trong môi trường sản xuất quy mô lớn, kiến trúc Tầng 2 được mở rộng thông qua hai giải pháp phần mềm chủ đạo: (1) Thay thế cơ chế suy luận đơn luồng bằng máy chủ suy luận phân tán (như vLLM hoặc TensorRT-LLM) hỗ trợ kỹ thuật PagedAttention và gom lô liên tục (Continuous Batching), cho phép tăng thông lượng suy luận mô hình 8B từ $15\times$ đến $30\times$ trên cụm từ 2 đến 4 GPU thương mại; (2) Thiết lập cơ chế hàng đợi ưu tiên phân tầng (Tiered Priority Queue), trong đó các cảnh báo có chỉ số đe dọa cao đi qua làn ưu tiên (Fast Lane) với độ trễ phản hồi tức thời, trong khi các sự kiện nghi vấn mức độ thấp được gom vào các lô xử lý nền (Background Batching), bảo đảm hạ tầng không bao giờ rơi vào trạng thái tắc nghẽn cục bộ.

Tóm lại, các kết quả thực nghiệm nêu trên chứng minh tính hữu dụng thực tiễn của hệ thống SENTINEL trước các ràng buộc vận hành của một SOC hiện đại. Ba trụ cột kiến trúc đỡ lấy kết quả đó—(1) Kinh tế học tầng lọc tốc độ cao ở Tầng 1 giúp xả tải 97,5% lưu lượng thô, rút ngắn độ trễ trung vị xuống 0,88 ms và đạt thông lượng 3.860 sự kiện/giây; (2) Lớp rào chắn đối kháng tất định kháng được toàn bộ 678 mẫu tiêm nhiễm khó nhờ Đóng gói Dữ liệu Phân định, kiểm chế nguy cơ né tránh không gian đặc trưng và niêm phong hồ sơ pháp y bằng chuỗi HMAC-SHA256; và (3) Năng lực suy luận nhận thức tác tử neo chứng cứ tại Tầng 2 giúp cô lập đe dọa với tỷ lệ bao phủ 95,0%, giảm 84,24% khối lượng phân tích cho

chuyên viên an ninh—SENTINEL cung cấp một nền tảng tái lập được để triển khai tác tử AI vào hạ tầng giám sát an ninh doanh nghiệp, trong phạm vi các giới hạn đã nêu.

Chương 5

Kết luận

Luận văn đã giải quyết triệt để nút thắt cổ chai lớn nhất trong việc ứng dụng Trí tuệ nhân tạo Tác tử (Agentic AI) vào Trung tâm Điều hành An ninh (SOC): đó là chi phí suy luận đắt đỏ, độ trễ tính toán lớn và nguy cơ ảo giác kỹ thuật khi xử lý luồng cảnh báo an ninh mạng quy mô lớn. Thông qua thiết kế và thực nghiệm hệ thống SENTINEL trên kiến trúc hai tầng vận hành cục bộ trên GPU máy trạm, nghiên cứu chứng minh ba đóng góp cốt lõi cho lĩnh vực An ninh mạng và AI Security.

Thứ nhất, nghiên cứu đề xuất và bảo chứng mô hình Kinh tế học Tầng lọc (Filtration Economics) trong giám sát an ninh mạng. Bằng việc kết hợp luật chữ ký tầng ứng dụng, bộ lọc thống kê Welford $\mathcal{O}(1)$, và Cổng Học máy LightGBM, Tầng 1 xả tải 97,5% lưu lượng SOC (loại bỏ 97.199 lời gọi mô hình ngôn ngữ), giảm độ trễ trung vị từ 17.174,7 ms xuống 0,88 ms (rút ngắn 19.500 lần ở mức trung vị) và đạt thông lượng 3.860 sự kiện/giây với 0 GPU VRAM ở Tầng 1. Về phương pháp luận, mỗi tỷ lệ xả tải đều gắn với tỷ lệ tấn công nền của luồng sinh ra nó, thay vì trình bày như một hằng số của hệ thống.

Thứ hai, nghiên cứu thiết lập rào chắn an ninh đối kháng tất định và niêm phong mật mã kiểm toán. Cơ chế Đóng gói Dữ liệu Phân định (Delimited Data Encapsulation) tại Tầng 2 cô lập cấu trúc tất định, triệt hạ 100% các kỹ thuật tiêm nhiễm câu lệnh qua nhật ký (Log Prompt Injection) trên 678 mẫu đối kháng phức tạp mà lớp lọc tĩnh sơ cấp bị mù hoàn toàn, ngăn chặn nguy cơ chiếm quyền tác tử. Chuỗi băm mật mã HMAC-SHA256 liên kết nối tiếp đạt tỷ lệ phát hiện 100% đối với ba dạng xâm phạm cốt lõi (sửa đổi nội dung bản ghi, chèn bản ghi giả và xóa bản ghi ở giữa) với 0 báo động giả, bảo đảm tính toàn vẹn và chống chối bỏ cho điều tra pháp y.

Thứ ba, nghiên cứu xây dựng mô hình suy luận nhận thức tác tử LangGraph kết hợp Dual-

RAG và rào chắn neo bằng chứng (Evidence-Anchoring Guardrail). Tác tử Tầng 2 đạt trần truy xuất tri thức MITRE ATT&CK 80,0% (Hit@3 đạt 0,93) và độ chính xác quy kết toàn tuyến 68,0%, với phán quyết quy kết bị ràng buộc trong tập mã kỹ thuật hiện diện ở chứng cứ đã truy xuất. Đồng thời, thông qua phiếu phân loại nhận thức, tác tử hoãn 15,76% cảnh báo nghi vấn để cô lập 95,0% đe dọa thực sự (tăng 6,03 lần mật độ đe dọa), cắt giảm 84,24% lượng tài liệu chuyên viên an ninh phải phân tích thủ công.

Bên cạnh kết quả đạt được, kiến trúc SENTINEL vẫn tồn tại một số hạn chế kỹ thuật cần ghi nhận. Độ chính xác quy kết toàn tuyến (68,0%) bị giới hạn bởi độ phủ tri thức RAG đối với các kỹ thuật hiếm (kỹ thuật T1083 chỉ đạt Hit@3 bằng 0,00), buộc rào chắn neo chứng cứ phải ép phán quyết về N/A và chuyển sang trạng thái hoãn, tạo khoảng lệch 12,0 điểm phần trăm so với trần truy xuất nhằm triệt tiêu nguy cơ ảo giác. Đánh giá RAGAS ghi nhận điểm chuẩn xác ngữ cảnh đạt 2,54/5,0 do đặc thù tích hợp đa tri thức NIST/MITRE và sự ưu tiên cho độ bao phủ ngữ cảnh (4,11/5,0), và tỷ lệ trích dẫn trực tiếp bản ghi nhật ký thô mới đạt 11,2% (KTC 95% 9,5–13,3%). Hai giới hạn kiến trúc tiếp tục ràng buộc phạm vi kết quả hiện tại: Tầng 2 vận hành như một đồ thị LangGraph đơn lẻ chưa phân vai chuyên biệt, nên các chiến dịch tấn công nhiều giai đoạn đồng thời được xử lý tuần tự thay vì song song; và toàn bộ phép đo thực nghiệm ban đầu được thu thập trên máy trạm một GPU, do đó mặc dù bài toán mở rộng định lượng lên hàng tỷ sự kiện/ngày đã được phân tích tại Mục 4.4, việc đo đạc vật lý trên cụm phân tán đa GPU quy mô lớn vẫn là mục tiêu kiểm chứng ở các giai đoạn tiếp theo.

Từ thực tiễn thực nghiệm, nghiên cứu mở ra các luồng phát triển mở rộng trong tương lai. Một luồng trọng tâm là tự động hóa quy trình cập nhật kho tri thức RAG từ nguồn Tình báo Môi đe dọa Mạng (CTI STIX/TAXII) thời gian thực kết hợp thuật toán nén ngữ cảnh nhằm xóa điểm mù Zero-day. Luồng phát triển khác là tinh chỉnh mô hình (Fine-tuning / DPO) trên tập nhật ký an ninh mạng nội địa để nâng cao độ chính xác quy kết và cường chế trích dẫn trọn vẹn bản ghi kiểm toán. Luồng thứ ba khắc phục giới hạn đồ thị đơn lẻ bằng cách mở rộng Tầng 2 thành cấu hình đa tác tử phân vai chuyên biệt cho phân tích tải trọng, tương quan chiến dịch và thực thi phản hồi. Luồng thứ tư nhắm tới dư địa thông lượng ở quy mô hạ tầng: cài đặt lại cổng Tầng 1 bằng ngôn ngữ lập trình hệ thống và phục vụ Tầng

2 qua vLLM PagedAttention. Cuối cùng, hệ thống có thể mở rộng tích hợp chữ ký số bất đối xứng (Ed25519) và neo bám định kỳ ra ngoài môi trường phân tán để đạt khả năng chống chối bỏ pháp lý tuyệt đối cho các hạ tầng an ninh mạng trọng yếu.

Khép lại một nỗ lực nghiên cứu nghiêm túc, nhưng mở ra những khát vọng sâu xa trong hành trình bảo vệ không gian số bằng sức mạnh của Trí tuệ Nhân tạo Tác tử.

Tài liệu tham khảo

- [1] G. González-Granadillo, S. González-Zarzosa, and R. Diaz, “Security Information and Event Management (SIEM): Analysis, Trends, and Usage in Critical Infrastructures,” *Sensors*, vol. 21, no. 14, art. 4759, 2021.
- [2] S. Tariq, M. Baruwat Chhetri, S. Nepal, and C. Paris, “Alert Fatigue in Security Operations Centers: Research Challenges and Opportunities,” *ACM Computing Surveys*, vol. 57, no. 9, art. 224, 2025.
- [3] B. A. AlAhmadi, L. Axon, and I. Martinovic, “99% False Positives: A Qualitative Study of SOC Analysts’ Perspectives on Security Alarms,” in *Proceedings of the 31st USENIX Security Symposium*, 2022, pp. 2783–2800.
- [4] Ismail, R. Kurnia, Z. A. Brata, G. A. Nelistiani, S. Heo, H. Kim, and H. Kim, “Toward Robust Security Orchestration and Automated Response in Security Operations Centers with a Hyper-Automation Approach Using Agentic Artificial Intelligence,” *Information*, vol. 16, no. 5, art. 365, 2025.
- [5] A. Vaswani *et al.*, “Attention is All You Need,” in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 30, 2017.
- [6] K. Greshake, S. Abdelnabi, S. Mishra, A. Endres, T. Holz, and M. Fritz, “More than you’ve asked for: A Comprehensive Analysis of Novel Prompt Injection Threats to Application-Integrated Large Language Models,” *arXiv preprint arXiv:2302.12173*, 2023.
- [7] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, “Zero Trust Architecture,” NIST Special Publication 800-207, National Institute of Standards and Technology, 2020.
- [8] OWASP GenAI Security Project, “OWASP Top 10 for Large Language Model Applications,” Version 2025, The OWASP Foundation, 2025. [Online]. Available: <https://genai.owasp.org/> [Accessed: Aug. 10, 2026].
- [9] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, “Toward Generating a New Intrusion Detection Dataset and Intrusion Traffic Characterization,” in *Proceedings of the 4th International Conference on Information Systems Security and Privacy (ICISSP)*, 2018, pp. 108–116.
- [10] C. Torrano-Giménez, A. Pérez-Villegas, and G. Álvarez Marañón, “HTTP DATASET CSIC 2010,” Information Security Institute, Spanish National Research Council (CSIC), 2010. [Online]. Available: <https://www.isi.csic.es/dataset/HTTP> [Accessed: Aug. 10, 2026].
- [11] S. Myneni, A. Chowdhary, A. Sabur, S. Sengupta, G. Agrawal, D. Huang, and M. Kang, “DAPT 2020 – Constructing a Benchmark Dataset for Advanced Persistent Threats,” in *Deployable Machine Learning for Security Defense (MLHat 2020)*, Communications in Computer and Information Science, vol. 1271, Springer, 2020, pp. 138–163.
- [12] A. Zou, Z. Wang, J. Z. Kolter, and M. Fredrikson, “Universal and Transferable Adversarial Attacks on Aligned Language Models,” *arXiv preprint arXiv:2307.15043*, 2023.
- [13] Deepset, “Prompt Injections Dataset,” *Hugging Face repository*, 2023. [Online]. Available: <https://huggingface.co/datasets/deepset/prompt-injections> [Accessed:

Aug. 10, 2026].

- [14] jackhhao, “Jailbreak Classification Dataset,” *Hugging Face repository*, 2023. [Online]. Available: <https://huggingface.co/datasets/jackhhao/jailbreak-classification> [Accessed: Aug. 10, 2026].
- [15] R. Zuech, T. M. Khoshgoftaar, and R. Wald, “Intrusion Detection and Big Heterogeneous Data: A Survey,” *Journal of Big Data*, vol. 2, art. 3, 2015.
- [16] B. P. Welford, “Note on a Method for Calculating Corrected Sums of Squares and Products,” *Technometrics*, vol. 4, no. 3, pp. 419–420, 1962.
- [17] G. Ke, Q. Meng, T. Finley, T. Wang, W. Chen, W. Ma, Q. Ye, and T.-Y. Liu, “LightGBM: A Highly Efficient Gradient Boosting Decision Tree,” in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 30, 2017.
- [18] A. Gholami *et al.*, “A Survey of Quantization Methods for Efficient Neural Network Inference,” *arXiv preprint arXiv:2103.13630*, 2021.
- [19] S. Weerawardhena, P. Kassianik, B. Nelson, B. Saglam *et al.* (Cisco Foundation AI), “Llama-3.1-FoundationAI-SecurityLLM-8B-Instruct Technical Report,” *arXiv preprint arXiv:2508.01059*, 2025.
- [20] P. Kassianik, B. Saglam *et al.* (Cisco Foundation AI), “Llama-3.1-FoundationAI-SecurityLLM-Base-8B Technical Report,” *arXiv preprint arXiv:2504.21039*, 2025.
- [21] LangChain AI, “LangGraph: Multi-Actor, Stateful LLM Applications,” *GitHub repository*, 2024. [Online]. Available: <https://github.com/langchain-ai/langgraph> [Accessed: Aug. 10, 2026].
- [22] P. Lewis *et al.*, “Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks,” in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 33, 2020.
- [23] J. Johnson, M. Douze, and H. Jégou, “Billion-Scale Similarity Search with GPUs,” *IEEE Transactions on Big Data*, vol. 7, no. 3, pp. 535–547, 2021.
- [24] S. Robertson and H. Zaragoza, “The Probabilistic Relevance Framework: BM25 and Beyond,” *Foundations and Trends in Information Retrieval*, vol. 3, no. 4, pp. 333–389, 2009.
- [25] G. V. Cormack, C. L. A. Clarke, and S. Buettcher, “Reciprocal Rank Fusion Outperforms Condorcet and Individual Rank Learning Methods,” in *Proceedings of the 32nd International ACM SIGIR Conference on Research and Development in Information Retrieval*, 2009, pp. 758–759.
- [26] B. E. Strom, A. Applebaum, D. P. Miller, K. C. Nickels, A. G. Pennington, and C. B. Thomas, “MITRE ATT&CK: Design and Philosophy,” The MITRE Corporation, Technical Report MP180360, 2018.
- [27] P. Cichonski, T. Millar, T. Grance, and K. Scarfone, “Computer Security Incident Handling Guide,” NIST Special Publication 800-61 Revision 2, National Institute of Standards and Technology, 2012.
- [28] R. Pandey and A. Bhujang, “Poisoning the Watchtower: Prompt Injection Attacks Against LLM-Augmented Security Operations Through Adversarial Log Content,” *arXiv preprint arXiv:2605.24421*, 2026.
- [29] H. Krawczyk, M. Bellare, and R. Canetti, “HMAC: Keyed-Hashing for Message Authentication,” Internet Engineering Task Force, RFC 2104, 1997.
- [30] J. Zhang *et al.*, “When LLMs Meet Cybersecurity: A Systematic Literature Review,” *Cybersecurity*, vol. 8, 2025.
- [31] P. He, J. Zhu, S. He, J. Li, and M. R. Lyu, “Drain: An Online Log Parsing Approach with Fixed Depth Tree,” in *Proceedings of the IEEE International Conference on Web*

- Services (ICWS)*, 2017, pp. 33–40.
- [32] F. Blefari, C. Cosentino, F. A. Pironti, A. Furfaro, and F. Marozzo, “CyberRAG: An Agentic RAG cyber attack classification and reporting tool,” *Future Generation Computer Systems*, vol. 176, art. 108186, 2026.
 - [33] Z. Liu and A. Anwar, “AutoBnB-RAG: Enhancing Multi-Agent Incident Response with Retrieval-Augmented Generation,” *arXiv preprint arXiv:2508.13118*, 2025.
 - [34] A. Abdennebi, N. Kara, L. Lahlou, and H. Ould-Slimane, “LanG – A Governance-Aware Agentic AI Platform for Unified Security Operations,” *arXiv preprint arXiv:2604.05440*, 2026.
 - [35] R. Sahay *et al.*, “Policy-Guided Threat Hunting: An LLM Enabled Framework with Splunk SOC Triage,” *arXiv preprint arXiv:2603.23966*, 2026.
 - [36] K. Peffers, T. Tuunanen, M. A. Rothenberger, and S. Chatterjee, “A Design Science Research Methodology for Information Systems Research,” *Journal of Management Information Systems*, vol. 24, no. 3, pp. 45–77, 2007.
 - [37] OWASP Foundation, “OWASP Top 10:2021 - The Ten Most Critical Web Application Security Risks,” The OWASP Foundation, 2021. [Online]. Available: <https://owasp.org/Top10/> [Accessed: Aug. 10, 2026].
 - [38] N. Reimers and I. Gurevych, “Sentence-BERT: Sentence Embeddings using Siamese BERT-Networks,” in *Proceedings of the Conference on Empirical Methods in Natural Language Processing (EMNLP)*, 2019.
 - [39] X. Shen, Z. Chen, M. Backes, Y. Shen, and Y. Zhang, “‘Do Anything Now’: Characterizing and Evaluating In-The-Wild Jailbreak Prompts on Large Language Models,” in *Proceedings of the 2024 ACM SIGSAC Conference on Computer and Communications Security (CCS)*, 2024, pp. 1671–1685.
 - [40] S. Es, J. James, L. Espinosa-Anke, and S. Schockaert, “RAGAS: Automated Evaluation of Retrieval Augmented Generation,” *arXiv preprint arXiv:2309.15217*, 2023.
 - [41] L. Zheng *et al.*, “Judging LLM-as-a-Judge with MT-Bench and Chatbot Arena,” in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 36, 2023.